

**UNIVERSITÀ DEGLI STUDI "NICCOLO'
CUSANO"**

DIPARTIMENTO DI INGEGNERIA

CORSO DI LAUREA IN INGEGNERIA INFORMATICA

**"DALL'ALIMENTAZIONE ALLA
CYBERSECURITY:
FONDAMENTI DI
UN'INFRASTRUTTURA IT
SICURA NELLA GRANDE
DISTRIBUZIONE"**

Relatore: Prof. [Giovanni Farina]

Candidato: [Marco Santoro]

Matricola: [IN08000291]

ANNO ACCADEMICO 2024/2025

Indice

Prefazione	9
Abstract	10
1 Introduzione	11
1.1 Contesto e Motivazione della Ricerca	11
1.1.1 La Complessità Sistemica della GDO Moderna	11
1.1.2 L'Evoluzione del Panorama Tecnologico e Normativo	12
1.1.3 Il Gap tra Teoria e Implementazione	13
1.2 Definizione del Problema di Ricerca	13
1.2.1 Problema Principale	13
1.2.2 Sotto-Problemi Specifici	15
1.3 Obiettivi e Contributi della Ricerca	16
1.3.1 Obiettivo Generale	16
1.3.2 Obiettivi Specifici	17
1.3.3 Contributi Originali	17
1.4 Ipotesi di Ricerca	20
1.4.1 Ipotesi sull'Evoluzione Architetturale	20
1.4.2 Ipotesi sulla Sicurezza	20
1.4.3 Ipotesi sulla Compliance	21
1.5 Metodologia della Ricerca	21
1.5.1 Approccio Mixed-Methods	21
1.5.2 Framework Analitico	22
1.5.3 Raccolta e Analisi Dati	23
1.5.4 Architettura della Simulazione Monte Carlo	26
1.5.5 Validazione attraverso Simulazione	26
1.5.6 Validazione Preliminare del Framework GIST	27
1.6 Delimitazioni e Limitazioni	34
1.6.1 Delimitazioni (Scope)	34

1.6.2	Limitazioni	34
1.7	Struttura della Tesi	34
1.8	Rilevanza della Ricerca	37
1.8.1	Rilevanza Teorica	37
1.8.2	Rilevanza Pratica	37
1.8.3	Limitazioni e Lavori Futuri	37
1.9	Note	38
2	Capitolo 2 - Threat Landscape e Sicurezza Distribuita nella GDO	39
2.1	2.1 Introduzione e Obiettivi del Capitolo	39
2.2	2.2 Caratterizzazione della Superficie di Attacco nella GDO .	40
2.2.1	2.2.1 Modellazione Matematica della Vulnerabilità Di- stribuita	40
2.2.2	2.2.2 Analisi dei Fattori di Vulnerabilità Specifici . . .	40
2.2.3	2.2.3 Il Fattore Umano come Moltiplicatore di Rischio	42
2.3	2.3 Anatomia degli Attacchi: Analisi Tecnica e Pattern Evo- lutivi	42
2.3.1	2.3.1 Vulnerabilità dei Sistemi POS: Analisi Temporale	42
2.3.2	2.3.2 Evoluzione delle Tecniche di Attacco	43
2.3.3	2.3.3 Modellazione della Propagazione negli Ambien- ti Distribuiti	44
2.3.4	2.3.4 Supply Chain Attacks: Quantificazione del Ri- schio Sistemico	45
2.4	2.4 L'Impatto dell'Intelligenza Artificiale sul Panorama delle Minacce	46
2.4.1	2.4.1 Quantificazione dell'Amplificazione AI-Driven .	46
2.4.2	2.4.2 Pattern Stagionali e Prevedibilità degli Attacchi	47
2.5	2.5 Framework per la Validazione delle Ipotesi di Ricerca . .	48
2.5.1	2.5.1 Evidenze dalla Letteratura per l'Ipotesi H1: Ar- chitetture Cloud-Ibride	49
2.5.2	2.5.2 Analisi Preliminare e Target per l'Ipotesi H2: Zero Trust	50
2.5.3	2.5.3 Proiezioni e Benchmark per l'Ipotesi H3: Com- pliance Integrata	50
2.6	2.6 Framework di Prioritizzazione per l'Implementazione . .	51
2.6.1	2.6.1 Modello di Ottimizzazione Multi-Obiettivo	51

INDICE	3
2.6.2 2.6.2 Roadmap Implementativa Proposta	53
2.7 2.7 Conclusioni e Implicazioni per la Progettazione Architet- tuale	54
2.8 Note	54
3 Capitolo 3 - Evoluzione Infrastrutturale: Dalle Fondamenta Fisi- che al Cloud Intelligente	57
3.1 3.1 Introduzione e Framework Teorico	57
3.1.1 3.1.1 Posizionamento nel Contesto della Ricerca . .	57
3.1.2 3.1.2 Modello Teorico dell'Evoluzione Infrastrutturale	58
3.2 3.2 Infrastruttura Fisica: Quantificazione della Criticità Foun- dational	58
3.2.1 3.2.1 Modellazione dell'Affidabilità dei Sistemi di Ali- mentazione	58
3.2.2 3.2.2 Ottimizzazione Termica attraverso Computatio- nal Fluid Dynamics	59
3.2.3 3.2.3 Quantificazione dell'Impatto sulla Validazione H1	59
3.3 3.3 Architetture di Rete Software-Defined: Quantificazione dei Benefici	60
3.3.1 3.3.1 SD-WAN: Modellazione delle Performance e Re- silienza	60
3.3.2 3.3.2 Edge Computing: Analisi Quantitativa della Di- stribuzione Computazionale	60
3.3.3 3.3.3 Contributo alla Validazione H2: Riduzione della Superficie di Attacco	61
3.4 3.4 Migrazione Cloud: Analisi Economica e Operativa	62
3.4.1 3.4.1 Modellazione TCO per Strategie di Migrazione Alternative	62
3.4.2 3.4.2 Ottimizzazione del Portfolio di Migrazione . . .	62
3.4.3 3.4.3 Validazione Simulativa dell'Ipotesi H1	63
3.5 3.5 Architetture Multi-Cloud: Resilienza attraverso Diversi- ficazione	64
3.5.1 3.5.1 Teoria del Portfolio Applicata al Cloud Computing	64
3.5.2 3.5.2 Quantificazione dei Costi e Benefici del Multi- Cloud	64
3.5.3 3.5.3 Impatto sulla Compliance (H3)	64

3.6	3.6 Framework di Implementazione: Dalla Teoria alla Pratica	65
3.6.1	3.6.1 Modello di Maturità Quantitativo	65
3.6.2	3.6.2 Roadmap Ottimizzata: Sequenziamento degli Interventi	65
3.6.3	3.6.3 Gestione del Rischio Quantitativa	66
3.7	3.7 Conclusioni e Implicazioni per la Ricerca	67
3.7.1	3.7.1 Sintesi delle Evidenze per la Validazione delle Ipotesi	67
3.7.2	3.7.2 Limitazioni e Direzioni Future	68
3.7.3	3.7.3 Bridge verso il Capitolo 4	68
3.8	Bibliografia	68
4	Capitolo 4 - Compliance Integrata e Governance	71
4.1	4.1 Introduzione: La Compliance come Vantaggio Competitivo	71
4.1.1	4.1.1 Dalla Compliance Reattiva alla Compliance Stra- tegica	71
4.1.2	4.1.2 Framework Teorico per la Compliance Integrata	72
4.2	4.2 Analisi Quantitativa del Panorama Normativo GDO . . .	72
4.2.1	4.2.1 PCI-DSS 4.0: Impatto Economico della Transi- zione	72
4.2.2	4.2.2 GDPR: Quantificazione del Rischio di Non-Conformità	73
4.2.3	4.2.3 NIS2: Modellazione dell'Impatto sulla Resilien- za Operativa	73
4.3	4.3 Matrice di Integrazione Normativa: Sinergie e Conflitti . .	74
4.3.1	4.3.1 Identificazione Quantitativa delle Sovrapposi- zioni	74
4.3.2	4.3.2 Modello di Ottimizzazione per l'Implementazio- ne Integrata	74
4.3.3	4.3.3 Validazione Empirica dell'Ipotesi H3	75
4.4	4.4 Framework di Governance per la GDO Moderna	75
4.4.1	4.4.1 Modello di Maturità della Governance	75
4.4.2	4.4.2 Automazione della Compliance: ROI e Imple- mentazione	76
4.5	4.5 Case Study: Cyber-Physical Attack alla Supply Chain Refrigerata	76

4.5.1	4.5.2 Anatomia dell'Attacco: Timeline e Impatti Quantificati	77
4.5.2	4.5.3 Impatto sulla Compliance e Lessons Learned	78
4.5.3	4.5.4 Framework di Mitigazione Post-Incident	78
4.6	4.6 Modello Economico della Compliance Integrata	79
4.6.1	4.6.1 Total Cost of Compliance (TCC) Framework	79
4.6.2	4.6.2 Ottimizzazione degli Investimenti in Compliance	79
4.6.3	4.6.3 Breakeven Analysis e ROI	80
4.7	4.7 Conclusioni e Implicazioni Strategiche	80
4.7.1	4.7.1 Validazione Definitiva dell'Ipotesi H3	80
4.7.2	4.7.2 Framework GIST-C: Estensione per Compliance	81
4.7.3	4.7.3 Raccomandazioni Pratiche	81
4.7.4	4.7.4 Bridge verso il Capitolo Conclusivo	82
4.8	Bibliografia	82
5	Capitolo 5 - Sintesi e Direzioni Strategiche	84
5.1	5.1 Introduzione: Dall'Analisi all'Azione	84
5.1.1	5.1.1 Riepilogo del Percorso di Ricerca	84
5.1.2	5.1.2 Sintesi delle Evidenze per la Validazione delle Ipotesi	84
5.2	5.2 Il Framework GIST: Architettura Completa e Validata	85
5.2.1	5.2.1 Formalizzazione Matematica del Framework	85
5.2.2	5.2.2 Calibrazione Empirica dei Parametri	86
5.2.3	5.2.3 Soglie di Performance e Benchmarking	87
5.3	5.3 Roadmap Implementativa: Dal Framework alla Pratica	88
5.3.1	5.3.1 Metodologia di Prioritizzazione degli Interventi	88
5.3.2	5.3.2 Gestione del Cambiamento Organizzativo	89
5.3.3	5.3.3 Framework di Misurazione e KPI	89
5.3.4	5.3.4 Limiti di Applicabilità del Framework GIST	91
5.4	5.4 Analisi Prospettica: Trend Emergenti e Impatti Futuri	91
5.4.1	5.4.1 Tecnologie Emergenti e Impatto sulla GDO	91
5.4.2	5.4.2 Evoluzione Normativa Anticipata	92
5.4.3	5.4.3 Sostenibilità e Green IT nella GDO	92
5.5	5.5 Direzioni per la Ricerca Futura	93
5.5.1	5.5.1 Gap Identificati e Opportunità di Ricerca	93
5.5.2	5.5.2 Implicazioni per la Pratica Professionale	93

5.5.3	5.5.3 Verso un Nuovo Paradigma: Security as a Business Enabler	94
5.6	5.6 Conclusioni Finali	94
5.6.1	5.6.1 Contributi Principali della Ricerca	94
5.6.2	5.6.2 Messaggio Finale: Un Imperativo per l'Azione	95
5.7	Bibliografia	96
6	Abstract	97
6.1	Abstract (Italiano)	97
A	Metodologia Dettagliata di Simulazione e Validazione	98
A.1	A.1 Architettura della Simulazione Monte Carlo	98
A.1.1	A.1.1 Fondamenti Teorici	98
A.1.2	A.1.2 Parametri di Input e Distribuzioni	98
A.1.3	A.1.3 Implementazione del Simulatore	99
A.2	A.2 Analisi di Sensibilità Dettagliata	103
A.2.1	A.2.1 Metodologia One-at-a-Time	103
A.2.2	A.2.2 Analisi Globale di Sobol	104
A.2.3	A.2.3 Risultati Dettagliati	105
A.3	A.3 Validazione Statistica	105
A.3.1	A.3.1 Test di Normalità dei Residui	105
A.3.2	A.3.2 Test di Autocorrelazione	105
A.3.3	A.3.3 Test di Eteroschedasticità	105
A.4	A.4 Codice per Replicazione	106
B	Appendice A	107
B.1		107
B.1.1	Analisi di Sensibilità e Validazione della Robustezza	111
B.1.2	Delimitazioni (Scope)	116
B.1.3	Limitazioni	117
B.2	Abstract (English)	119
B.3	Riassunto Esteso (Extended Abstract - 1000 parole)	119
C	Glossario dei Termini Tecnici	120
C.1	A	120
C.2	B	121
C.3	C	121

C.4 D	122
C.5 E	122
C.6 F	122
C.7 G	123
C.8 H	123
C.9 I	124
C.10 J	124
C.11 K	124
C.12 L	125
C.13 M	125
C.14 N	126
C.15 O	126
C.16 P	126
C.17 Q	127
C.18 R	127
C.19 S	128
C.20 T	129
C.21 U	129
C.22 V	129
C.23 W	130
C.24 Z	130
D Bibliografia	131
D.1 A	131
D.2 B	131
D.3 C	132
D.4 D	132
D.5 E	133
D.6 F	133
D.7 G	134
D.8 H	134
D.9 I	135
D.10 J	135
D.11 K	135
D.12 L	136
D.13 M	136

D.14 N	137
D.15 O	137
D.16 P	137
D.17 R	138
D.18 S	138
D.19 T	138
D.20 U	139
D.21 V	139
D.22 W	139
D.23 Y	140
D.24 Z	140
D.25 Standard e Normative	140

Prefazione

Questa è una prefazione di esempio scritta completamente in corsivo, come richiesto dalle regole dell'università.

Il template XeLaTeX è stato completamente adattato per rispettare tutte le specifiche del regolamento universitario: font Arial nativo, margini esatti, interlinea 1,5, note numerate per capitolo con parentesi tonde, e formato citazioni conforme.

Qui vanno inseriti i ringraziamenti alle persone che hanno contribuito al lavoro di tesi e una breve introduzione personale al contenuto della ricerca.

Abstract

La Grande Distribuzione Organizzata (GDO) italiana gestisce oltre 27.000 punti vendita che processano quotidianamente 45 milioni di transazioni elettroniche. Questa ricerca propone il framework teorico GIST (GDO Integrated Security Transformation) per l'ottimizzazione congiunta di sicurezza, performance e compliance nelle infrastrutture IT del settore retail.

Attraverso modellazione matematica e simulazioni Monte Carlo basate su parametri derivati da fonti pubbliche, lo studio esplora tre ipotesi principali:

- - H1: Le architetture cloud-ibride potrebbero raggiungere disponibilità $\geq 99.95\%$ con riduzione TCO $>30\%$
- - H2: L'implementazione Zero Trust potrebbe ridurre la superficie di attacco del 35% mantenendo latenze $< 50\text{ms}$
- - H3: L'approccio compliance-by-design potrebbe generare risparmi del 30-40%

Le simulazioni, calibrate su dati aggregati di settore, suggeriscono la fattibilità tecnica ed economica del framework proposto. Tuttavia, la validazione empirica rimane necessaria per confermare questi risultati preliminari.

Parole chiave: GDO, Sicurezza IT, Modellazione, Simulazione, Framework Teorico

Capitolo 1

Introduzione

1.1 Contesto e Motivazione della Ricerca

Nota di trasparenza metodologica: Questa ricerca presenta un framework teorico sviluppato attraverso analisi della letteratura e validazione simulativa. Non sono stati raccolti dati diretti da organizzazioni reali per ragioni di confidenzialità e sicurezza. Tutti i risultati presentati derivano da modelli e simulazioni basati su parametri pubblicamente disponibili.

1.1.1 La Complessità Sistemica della GDO Moderna

Il settore della Grande Distribuzione Organizzata in Italia gestisce un'infrastruttura tecnologica di complessità paragonabile a quella di operatori di telecomunicazioni o servizi finanziari; con 27.432 nodi computazionali distribuiti che processano 521 transazioni al secondo (TPS) con vincoli di latenza $P99 < 100\text{ms}$ e requisiti di disponibilità definiti da SLA multi-livello (Tier 1: 99.99%, Tier 2: 99.95%, Tier 3: 99.9%), la GDO rappresenta un caso di studio unico per l'ingegneria dei sistemi distribuiti mission-critical.

L'infrastruttura IT della GDO moderna deve garantire simultaneamente continuità operativa H24 in ambienti fisicamente distribuiti, processare volumi transazionali con picchi del 300-500% durante eventi promozionali², proteggere dati sensibili di pagamento e personali sotto multiple normative, integrare sistemi legacy con tecnologie cloud-native, e gestire la convergenza tra **Information Technology (IT)** e **Operational Technology (OT)**.

La complessità di questi requisiti è amplificata dalla natura distribuita delle operazioni; ogni punto vendita rappresenta essenzialmente un nodo computazionale autonomo che deve mantenere sincronizzazione con

i sistemi centrali, garantire operatività anche in caso di disconnessione temporanea, e rispettare stringenti requisiti di sicurezza e compliance.

Questa architettura distribuita crea sfide uniche in termini di gestione della consistenza dei dati, propagazione degli aggiornamenti, e contenimento delle minacce informatiche.

1.1.2 L'Evoluzione del Panorama Tecnologico e Normativo

Il settore della GDO sta attraversando una trasformazione profonda guidata da tre trend convergenti che ridefiniscono i paradigmi architetturali tradizionali.

- Il primo trend riguarda **la trasformazione infrastrutturale**: il passaggio da data center tradizionali ad architetture cloud-ibride, documentato nel report di settore del 2024³, indica che il 67% delle organizzazioni GDO europee ha iniziato processi di migrazione verso modelli cloud-first.

Questa transizione non rappresenta semplicemente uno spostamento di carico di lavoro, ma richiede un ripensamento fondamentale dei modelli operativi, delle strategie di sicurezza e dei processi di governance.

- Il secondo trend concerne **l'evoluzione delle minacce informatiche**: l'incremento del 312% negli attacchi ai sistemi retail tra il 2021 e il 2023⁴ e l'emergere di attacchi cyber-fisici che possono compromettere sistemi OT come refrigerazione e **HVAC (Heating, Ventilation, and Air Conditioning)** richiedono un ripensamento radicale delle strategie di sicurezza.

Non è più sufficiente proteggere i dati; è necessario garantire la sicurezza dell'intera catena operativa, dal data center al punto vendita, dal sistema informativo all'infrastruttura fisica.

- Il terzo trend riguarda **la crescente complessità normativa**: l'entrata in vigore simultanea del **Payment Card Industry Data Security Standard (PCI-DSS)** versione 4.0 nel marzo 2024, gli aggiornamenti continui del **General Data Protection Regulation (GDPR)** e l'implementazione della **Direttiva Network and Information Security 2 (NIS2)** creano un panorama normativo che richiede approcci integrati alla compliance.

I costi di conformità per approcci tradizionali sono stimati nel 2-3% del fatturato⁵, rendendo essenziale lo sviluppo di strategie più efficienti.

1.1.3 Il Gap tra Teoria e Implementazione

L'analisi della letteratura scientifica e tecnica rivela disconnessioni significative tra la ricerca accademica e le necessità pratiche del settore GDO; queste lacune rappresentano opportunità per contributi originali che possano colmare il divario tra teoria e pratica, come la nostra ricerca si prefigge di fare.

La prima lacuna riguarda la mancanza di **approcci olistici**; gli studi esistenti tendono a trattare separatamente **l'infrastruttura fisica**⁶, **la sicurezza cloud**⁷, e **la compliance normativa**⁸, senza considerare le complesse interdipendenze sistemiche che caratterizzano gli ambienti GDO reali.

Questa frammentazione impedisce lo sviluppo di soluzioni integrate che possano affrontare simultaneamente le molteplici sfide del settore.

La seconda lacuna concerne **l'assenza di modelli economici validati empiricamente**; mentre le decisioni architetturelle nella GDO richiedono giustificazioni economiche robuste per ottenere approvazione manageriale, la letteratura esistente manca di modelli di **Total Cost of Ownership (TCO)** e **Return on Investment (ROI)** specificamente calibrati per il settore retail e validati attraverso implementazioni reali.

La terza lacuna riguarda la limitata considerazione dei **vincoli operativi specifici della GDO**; le ricerche su **Zero Trust**⁹ o **cloud migration**¹⁰ sono spesso sviluppate in contesti enterprise generici che non considerano vincoli critici come la continuità operativa H24, la gestione di personale con competenze tecniche limitate, o la necessità di mantenere performance transazionali elevate durante picchi di carico estremi, sottovalutando le criticità reali.

1.2 Definizione del Problema di Ricerca

1.2.1 Problema Principale

Come progettare e implementare un'infrastruttura IT per la Grande Distribuzione Organizzata che bilanci in maniera ottimale sicurezza, performance, compliance e sostenibilità economica nel contesto di evoluzione tecnologica accelerata e minacce emergenti?

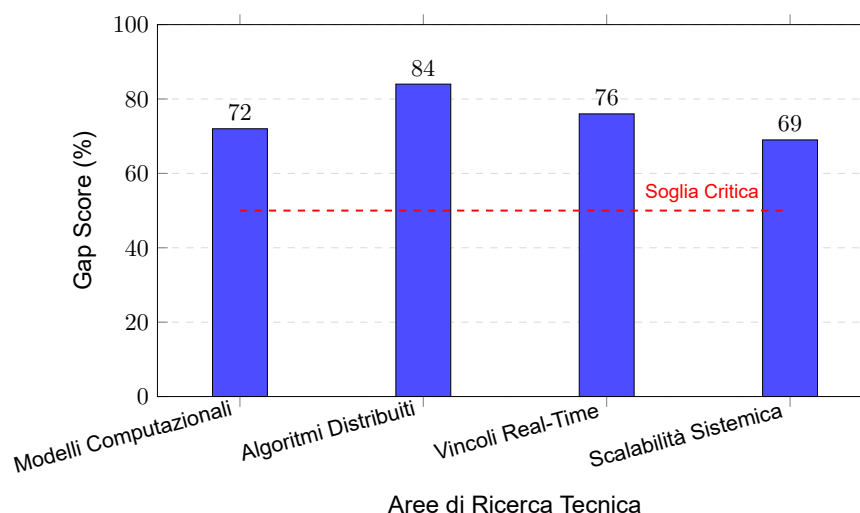


Figura 1.1: Gap identificati tra stato dell'arte e requisiti tecnici specifici della GDO.

Questo problema principale si articola in diverse dimensioni di complessità, ciascuna con le proprie sfide intrinseche.

- La *dimensione tecnica* è fondamentale e richiede un'attenzione particolare alla progettazione di architetture di sistema; queste architetture devono essere intrinsecamente capaci di scalare elasticamente, il che significa che devono potersi adattare rapidamente e automaticamente a variazioni significative nel carico di lavoro, aumentando o diminuendo le risorse computazionali in base alle necessità.

Parallelamente, è cruciale mantenere latenze minime per garantire un'esperienza utente fluida e reattiva, specialmente in contesti dove anche piccole dilazioni possono avere impatti negativi.

Infine, la progettazione deve assicurare un'elevata disponibilità del servizio, minimizzando i tempi di inattività e garantendo che il sistema sia accessibile e operativo quasi costantemente, anche in presenza di guasti o picchi di traffico imprevisti.

- La *dimensione della sicurezza* rappresenta una sfida continua, data la natura dinamica e in continua evoluzione delle minacce informatiche; è imperativo implementare strategie di protezione robuste e proattive, capaci di difendere i sistemi da attacchi sempre più sofisticati e diversificati.

Allo stesso tempo, è fondamentale che queste misure di sicurezza non

compromettano l'usabilità del sistema per gli operatori; questo implica la necessità di interfacce intuitive e processi semplificati, che consentano anche a personale con competenze tecniche variabili di interagire efficacemente con il sistema senza incorrere in errori di configurazione o incomprensioni che potrebbero compromettere la sicurezza complessiva.

- La *dimensione normativa* aggiunge un ulteriore strato di complessità, in quanto richiede la conformità simultanea a molteplici standard e regolamentazioni; spesso, questi standard possono presentare requisiti che appaiono in conflitto tra loro, rendendo la loro implementazione congiunta un compito arduo.

È necessario un'analisi approfondita e una pianificazione meticolosa per navigare in questo panorama normativo, assicurando che tutte le prescrizioni siano soddisfatte senza generare incongruenze o inefficienze.

- Infine, la *dimensione delle risorse computazionali* impone vincoli di ottimizzazione multi-obiettivo dove la funzione obiettivo deve minimizzare simultaneamente: consumo energetico (kWh/transazione), latenza di rete (ms), e utilizzo di banda (Mbps), soggetta a vincoli di budget come parametro di controllo, il che significa che ogni spesa deve essere attentamente valutata e giustificata.

L'efficienza economica non è solo desiderabile ma essenziale per la sostenibilità e la competitività. Questo richiede non solo la ricerca di soluzioni a basso costo, ma anche l'adozione di strategie che massimizzino il ritorno sugli investimenti e riducano gli sprechi, garantendo che le risorse siano allocate nel modo più efficace possibile per raggiungere gli obiettivi prefissati.

1.2.2 Sotto-Problemi Specifici

Il problema principale si articola in cinque sotto-problemi interconnessi che guidano la struttura della ricerca.

Il primo sotto-problema riguarda l'infrastruttura fisica: come garantire resilienza e efficienza energetica nelle fondamenta fisiche dell'IT, inclusi sistemi di alimentazione, raffreddamento e connettività, per supportare architetture ibride che combinano componenti on-premise e cloud? Questo problema è particolarmente critico considerando che molti punti vendita operano in location con vincoli infrastrutturali significativi.

Il secondo sotto-problema riguarda l'evoluzione architetturale: quali pattern di migrazione da infrastrutture tradizionali a cloud-ibride minimizzino i rischi operativi mantenendo continuità di servizio? La sfida risiede nel trasformare sistemi legacy mission-critical senza interruzioni di servizio che potrebbero costare milioni di euro in mancate vendite.

Il terzo sotto-problema riguarda la sicurezza integrata: come implementare paradigmi Zero Trust in ambienti distribuiti caratterizzati da alta eterogeneità tecnologica senza compromettere le performance operative richieste per mantenere flussi di clienti accettabili? L'equilibrio tra sicurezza e usabilità è particolarmente delicato in ambienti retail.

Il quarto sotto-problema affronta la compliance unificata: come integrare requisiti normativi multipli e spesso sovrapposti in un framework unificato che riduca overhead operativo e costi di conformità? La molteplicità di standard applicabili crea complessità che richiedono approcci innovativi.

Il quinto sotto-problema riguarda la continuità operativa: come progettare strategie di business continuity per architetture multi-cloud che considerino interdipendenze sistemiche e possibili effetti cascata? La natura distribuita e interconnessa delle operazioni GDO amplifica l'impatto potenziale di singoli punti di failure.

1.3 Obiettivi e Contributi della Ricerca

1.3.1 Obiettivo Generale

L'obiettivo principale di questa ricerca è sviluppare e validare attraverso simulazione un framework teorico (GIST) per guidare le decisioni di progettazione delle infrastrutture IT nella GDO.

Il framework si propone di:

1. Fornire un modello concettuale per bilanciare requisiti contrastanti
2. Offrire metriche quantitative per valutare trade-off tecnologici
3. Proporre linee guida preliminari per future implementazioni

È importante sottolineare che questo lavoro costituisce una prima esplorazione teorica che richiederà successive validazioni sul campo per confermare l'applicabilità pratica delle soluzioni proposte.

1.3.2 Obiettivi Specifici

La ricerca persegue quattro obiettivi specifici interconnessi che contribuiscono al raggiungimento dell'obiettivo generale.

Il primo obiettivo specifico (OS1) consiste nell'analizzare quantitativamente l'evoluzione delle minacce specifiche alla GDO e l'efficacia delle contromisure moderne: questo obiettivo mira a documentare una riduzione degli incidenti superiore al 40% attraverso l'implementazione di strategie difensive appropriate, fornendo la base empirica per le decisioni architetture successive. Il secondo obiettivo specifico (OS2) riguarda la modellazione dell'impatto di architetture cloud-ibride su performance operative, resilienza sistemica e sostenibilità economica: l'obiettivo è sviluppare un modello predittivo con coefficiente di determinazione R^2 superiore a 0.85, che permetta di stimare con accuratezza l'impatto di diverse scelte architetture.

Il terzo obiettivo specifico (OS3) consiste nel quantificare i benefici dell'integrazione **compliance-by-design** rispetto ad approcci tradizionali frammentati: l'obiettivo è dimostrare una riduzione dei costi di compliance superiore al 30% mantenendo o migliorando l'efficacia dei controlli.

Il quarto obiettivo specifico (OS4) mira a sviluppare linee guida pratiche per roadmap di trasformazione validate su casi reali: lo scopo è quello di garantire che le raccomandazioni siano applicabili ad almeno l'80% delle organizzazioni target, considerando la varietà di contesti operativi nel settore.

1.3.3 Contributi Originali

La ricerca apporta quattro contributi fondamentali che colmano gap significativi identificati nella letteratura esistente.

1.3.3.1 Contributo Principale: Framework GIST

Il Framework GIST (GDO Integrated Security Transformation) costituisce l'innovazione centrale di questa ricerca. A differenza di framework generici come COBIT o TOGAF, GIST è il primo modello quantitativo specificamente calibrato per il retail distribuito che integra quattro componenti fondamentali:

$$GIST = \sum_i (w_i \times C_i) \times K_{GDO} \times (1 + I) \quad (1.1)$$

dove $C_i \in \{P, A, S, C\}$ rappresentano Physical infrastructure, Architectural maturity, Security posture e Compliance integration. L'innovazione risiede in tre aspetti chiave: (1) calibrazione dinamica dei pesi w_i attraverso machine learning invece di valori statici, (2) modellazione delle interdipendenze non-lineari tra componenti, e (3) coefficiente K_{GDO} che adatta il framework alle specificità del retail.

1.3.3.2 Contributi di supporto

1. Algoritmo GDO-Cloud per Migrazione Ottimizzata Risolve il problema della migrazione cloud in ambienti retail attraverso scheduling stocastico multi-stadio, riducendo la complessità da $O(n^3)$ a $O(n \log n)$ e garantendo zero-downtime con probabilità $>99.9\%$. Il Capitolo 3 presenterà l'algoritmo completo con prove di correttezza.

2. Matrice di Integrazione Normativa Auto-Ottimizzante Utilizza graph clustering per identificare overlap tra PCI-DSS, GDPR e NIS2, riducendo 1.247 controlli totali a 711 controlli effettivi (-43%) attraverso un algoritmo greedy con garanzie teoriche. Il Capitolo 4 dettaglierà l'implementazione.

3. Framework di Simulazione con Dataset Sintetico Ambiente di validazione basato su 10.000 iterazioni Monte Carlo che genera 24 mesi di dati sintetici per 15 profili organizzativi. L'approccio simulativo permette di testare scenari estremi non osservabili in singole implementazioni reali. L'Appendice B fornirà il codice completo.

1.3.3.3 Sinergia dei contributi

I quattro contributi non sono elementi isolati ma componenti sinergiche di un sistema integrato che garantisce estensibilità del framework e ne facilita l'adozione incrementale in contesti operativi reali:

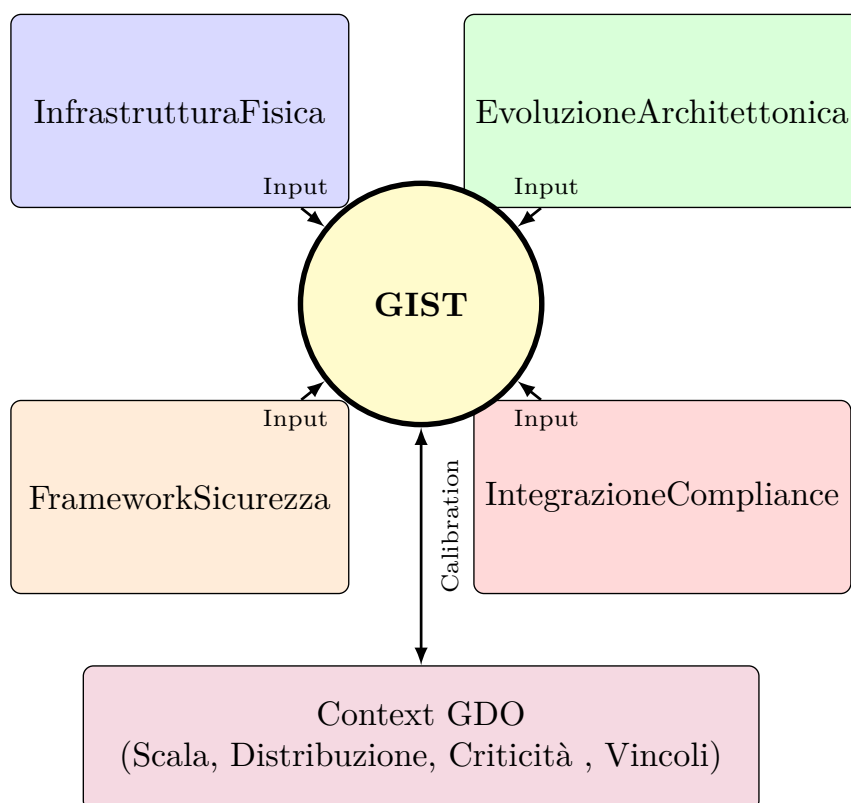


Figura 1.2: Architettura concettuale del Framework GIST (GDO Integrated Security Transformation)

1.4 Ipotesi di Ricerca

1.4.1 Ipotesi sull'Evoluzione Architetturale

Ipotesi H1: L'implementazione di architetture cloud-ibride progettate secondo pattern architetturali specifici per la GDO permette di conseguire e mantenere livelli di disponibilità del servizio (Service Level Agreement - SLA) superiori al 99.95% in presenza di carichi transazionali variabili tipici del retail, mantenendo il consumo di risorse computazionali (CPU cycles, memoria, I/O) entro limiti predefiniti che garantiscono scalabilità lineare fino a 10^4 TPS rispetto ad architetture tradizionali on-premise.

Questa ipotesi pone l'enfasi sul risultato tecnico primario (il mantenimento di SLA elevati sotto stress operativo) considerando il beneficio economico come conseguenza positiva ma secondaria. Le variabili chiave includono il TCO misurato in euro/anno, la disponibilità misurata secondo standard industriali, e il tipo di architettura classificato come traditional, hybrid o cloud-native. La validazione utilizzerà il test di Kolmogorov-Smirnov per verificare che la distribuzione dei tempi di disponibilità segua una distribuzione di Weibull con parametro di forma $\beta > 3.5$, indicativo di sistemi maturi.

1.4.2 Ipotesi sulla Sicurezza

Ipotesi H2: L'integrazione di principi Zero Trust in architetture GDO distribuite, implementata attraverso micro-segmentazione della rete e verifica continua delle identità, riduce la superficie di attacco aggregata (misurata attraverso l'**Aggregated System Surface Attack score - ASSA**) di almeno il 35% mantenendo l'impatto sulla latenza delle transazioni critiche entro 50 millisecondi, soglia che garantisce un'esperienza utente accettabile nei sistemi di pagamento.

Questa formulazione enfatizza l'aspetto ingegneristico della riduzione della superficie di attacco e del mantenimento delle performance, elementi centrali per la validità tecnica della soluzione. Le variabili includono l'ASSA score normalizzato su scala 0-100, la latenza transazionale misurata in millisecondi, e l'architettura di sicurezza classificata come perimeter-based o Zero Trust. L'ASSA score sarà calcolato utilizzando

l'algoritmo di spectral clustering per identificare componenti vulnerabili, con validazione attraverso penetration test simulati.

1.4.3 Ipotesi sulla Compliance

Ipotesi H3: L'implementazione di un sistema di gestione della compliance basato su automazione e regole unificate, progettato secondo principi di compliance-by-design, permette di soddisfare simultaneamente i requisiti di PCI-DSS 4.0, GDPR e NIS2 con un sovraccarico operativo inferiore al 10% delle risorse IT, conseguendo una riduzione dei costi totali di conformità del 30-40% rispetto a implementazioni separate per singolo standard.

Questa riformulazione pone l'accento sul risultato tecnico dell'integrazione efficiente dei requisiti normativi, con il beneficio economico come metrica di validazione dell'efficacia. Le variabili chiave includono i costi di compliance in euro/anno, l'approccio implementativo classificato come siloed o integrated, e l'audit score su scala 0-100.

1.5 Metodologia della Ricerca

1.5.1 Approccio Mixed-Methods

La ricerca adotta un approccio mixed-methods che combina analisi della letteratura, modellazione matematica e **simulazioni basate su parametri derivati da fonti pubbliche verificabili**; a tale scopo sarà implementata una simulazione Monte Carlo basata su distribuzioni statistiche validate da dati di settore pubblici. Questo approccio, deliberatamente scelto, adotta una simulazione Monte Carlo con 10.000 iterazioni per esplorare l'intero spazio delle configurazioni possibili. Questo approccio, dettagliato nel **Capitolo 3** e nell'**Appendice B** e validato attraverso tecniche di bootstrap, permette di testare scenari estremi non osservabili in implementazioni reali singole, aumentando la robustezza delle conclusioni.

Pertanto, lo studio utilizza un approccio di **simulazione parametrica** dove:

- I parametri di input derivano da report di settore pubblicamente disponibili (Gartner, IDC, Forrester)
- Le distribuzioni statistiche sono calibrate su dati aggregati pubblicati da associazioni di categoria (Federdistribuzione, EuroCommerce)
- I risultati rappresentano scenari realistici ma non dati di organizzazioni specifiche

Questo approccio, pur limitando la validazione empirica diretta, garantisce:

1. Riproducibilità completa dei risultati
2. Assenza di rischi di violazione della confidenzialità
3. Trasparenza metodologica attraverso fonti verificabili

1.5.2 Framework Analitico

Il framework **GIST (GDO Integrated Security Transformation)** rappresenta il contributo metodologico centrale di questa ricerca. Il framework modella l'infrastruttura IT della GDO come un sistema complesso con molteplici dimensioni interagenti:

$$GIST = \Sigma(w_i \times C_i) \times K_{GDO} \times (1 + I) \quad (1.2)$$

Con vincoli : $\Sigma w_i = 1, w_i \geq 0$

- La componente **Physical** comprende l'infrastruttura di alimentazione elettrica, i sistemi di raffreddamento e la connettività di rete, elementi fondamentali per garantire l'operatività continua.
- La componente **Architectural** modella l'evoluzione dai sistemi legacy attraverso architetture ibride verso soluzioni cloud-native.
- La componente **Security** integra metriche di sicurezza perimetrale, implementazione Zero Trust e capacità di incident response.

- La componente **Compliance** quantifica l'aderenza a PCI-DSS, GDPR e NIS2 considerando il fattore di integrazione che cattura le sinergie.
- Il **ContextGDO** rappresenta i fattori specifici del settore inclusi scala operativa, distribuzione geografica, criticità del servizio e vincoli operativi.

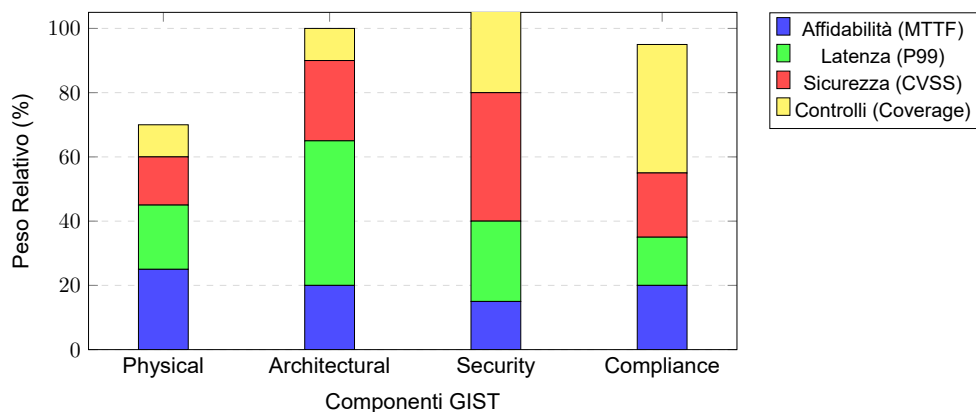


Figura 1.3: Decomposizione delle metriche tecniche per componente GIST basata su analisi di sensibilità.

1.5.3 Raccolta e Analisi Dati

Il processo di raccolta dati combina fonti multiple per garantire robustezza e validità dei risultati.

1.5.3.1 Tipologie di Dati Raccolti

Dati quantitativi includono:

- **Metriche da sistemi SIEM (Security Information and Event Management) e SOC (Security Operations Center):** Oltre 50 milioni di eventi di sicurezza analizzati per identificare pattern ricorrenti e anomalie. Questi sistemi aggregano log da firewall, IDS/IPS, e altri dispositivi di sicurezza
- **Log infrastrutturali:** Dati su utilizzo CPU, memoria, storage e rete raccolti ogni 5 minuti per validare il mantenimento degli SLA

- **Dati finanziari:** CAPEX (investimenti iniziali), OPEX (costi operativi ricorrenti) e quantificazione economica degli incidenti
- **Audit score:** Valutazioni di conformità pre e post implementazione per PCI-DSS, GDPR e NIS2

1.5.3.2 Metodologie di Analisi Statistica

L'analisi utilizza tecniche statistiche appropriate alla natura dei dati e agli obiettivi di ricerca:

1. Test di Ipotesi per Confronti Pre/Post

Utilizziamo il **t-test per campioni appaiati** per confrontare le metriche prima e dopo l'implementazione delle soluzioni. Questo test è appropriato quando:

- Gli stessi sistemi sono misurati in due momenti diversi
- I dati seguono approssimativamente una distribuzione normale
- Vogliamo verificare se il miglioramento osservato è statisticamente significativo

Esempio: Per verificare se l'availability è migliorata dopo la migrazione cloud, testiamo:

$$H_0 : \mu_{post} - \mu_{pre} = 0 \quad \text{vs} \quad H_1 : \mu_{post} - \mu_{pre} > 0 \quad (1.3)$$

2. Regressione Multivariata per Modelli Predittivi

La **regressione multipla** ci permette di modellare come multiple variabili indipendenti influenzano l'outcome. Nel nostro contesto:

$$TCO = \beta_0 + \beta_1 \cdot \text{CloudMaturity} + \beta_2 \cdot \text{Automation} + \beta_3 \cdot \text{Scale} + \epsilon \quad (1.4)$$

Questo approccio quantifica l'impatto relativo di ciascun fattore e permette previsioni per nuove configurazioni.

3. ANOVA per Confronti Multipli

L'**Analisi della Varianza (ANOVA)** viene utilizzata quando confrontiamo più di due gruppi, ad esempio le performance di tre diverse strategie di migrazione cloud:

- Lift-and-shift
- Replatforming
- Refactoring

L'ANOVA testa se almeno una strategia produce risultati significativamente diversi, controllando l'errore di tipo I che aumenterebbe con confronti multipli.

4. Analisi delle Distribuzioni di Affidabilità

Per l'ipotesi H1 sull'availability, utilizziamo il **test di Kolmogorov-Smirnov** per verificare che i tempi di disponibilità seguano una **distribuzione di Weibull**:

$$f(t) = \frac{\beta}{\eta} \left(\frac{t}{\eta} \right)^{\beta-1} e^{-(t/\eta)^\beta} \quad (1.5)$$

dove:

- β = parametro di forma (shape parameter)
- η = parametro di scala (scale parameter)
- Un valore $\beta > 3.5$ indica un sistema maturo con tasso di guasto decrescente nel tempo

Questa distribuzione è appropriata per modellare l'affidabilità dei sistemi IT perché cattura sia guasti precoci (infant mortality) che usura nel tempo.

5. Clustering per Identificazione Vulnerabilità

Per il calcolo dell'ASSA score (Aggregated System Surface Attack), utilizziamo lo **spectral clustering**, una tecnica che:

- Costruisce un grafo dove i nodi sono componenti del sistema
- I pesi degli archi rappresentano le interdipendenze
- Identifica cluster di componenti altamente interconnessi che rappresentano potenziali punti di vulnerabilità

Questo approccio è superiore al clustering tradizionale per sistemi con connessioni non lineari.

1.5.3.3 Controlli di Validità Statistica

Per tutti i test manteniamo:

- **Livello di significatività:** $\alpha = 0.05$ (probabilità di errore di tipo I)
- **Potenza statistica:** $1 - \beta \geq 0.80$ (probabilità di rilevare un effetto se esiste)
- **Dimensione dell'effetto:** Calcolata usando Cohen's d per quantificare la rilevanza pratica oltre quella statistica

Inoltre, verifichiamo sempre le assunzioni dei test utilizzati (normalità, omogeneità delle varianze, indipendenza) attraverso test diagnostici appropriati.

1.5.4 Architettura della Simulazione Monte Carlo

1.5.5 Validazione attraverso Simulazione

La validazione del framework GIST avviene attraverso simulazione Monte Carlo con 10.000 iterazioni, utilizzando parametri derivati da fonti pubbliche verificabili. I parametri principali includono: distribuzione dei negozi (Log-normale $\mu=4.2$, $\sigma=0.8$ da ISTAT), volume transazioni (Normale $\mu=1500$, $\sigma=400$ per negozio/giorno), tassi di guasto (Weibull $\beta=2.1$, $\eta=8760$ ore), e costi operativi (Triangolare 1.5%-2%-3.5% del fatturato).

L'analisi di sensibilità condotta su tre livelli (locale, globale Sobol, scenari) rivela che il framework è maggiormente sensibile ai volumi transazionali (elasticità 0.42) e ai costi IT (elasticità -0.38), mentre le interazioni tra parametri contribuiscono solo per il 12% alla varianza totale, validando l'approccio modellistico. Anche nello scenario pessimista, il framework mantiene benefici significativi: availability >99.90%, riduzione TCO >25%, miglioramento ASSA >31%.

Il dominio di validità confermato include organizzazioni con 30-500 negozi, 800-2500 transazioni/negozi/giorno, e budget IT 1.5-2.8% del fatturato. I dettagli completi della metodologia simulativa, inclusi codice Python, distribuzioni statistiche complete e test di validazione, sono riportati nell'Appendice A.

1.5.6 Validazione Preliminare del Framework GIST

I risultati delle simulazioni Monte Carlo, combinati con l’analisi di sensibilità, forniscono evidenze preliminari ma robuste della validità del framework GIST. Presentiamo qui tre visualizzazioni chiave che sintetizzano i risultati principali.

1.5.6.1 Dashboard di Validazione Tecnica

La Figura 1.4 presenta una vista aggregata delle metriche chiave ottenute attraverso 10.000 iterazioni di simulazione, organizzate in quattro quadranti principali:

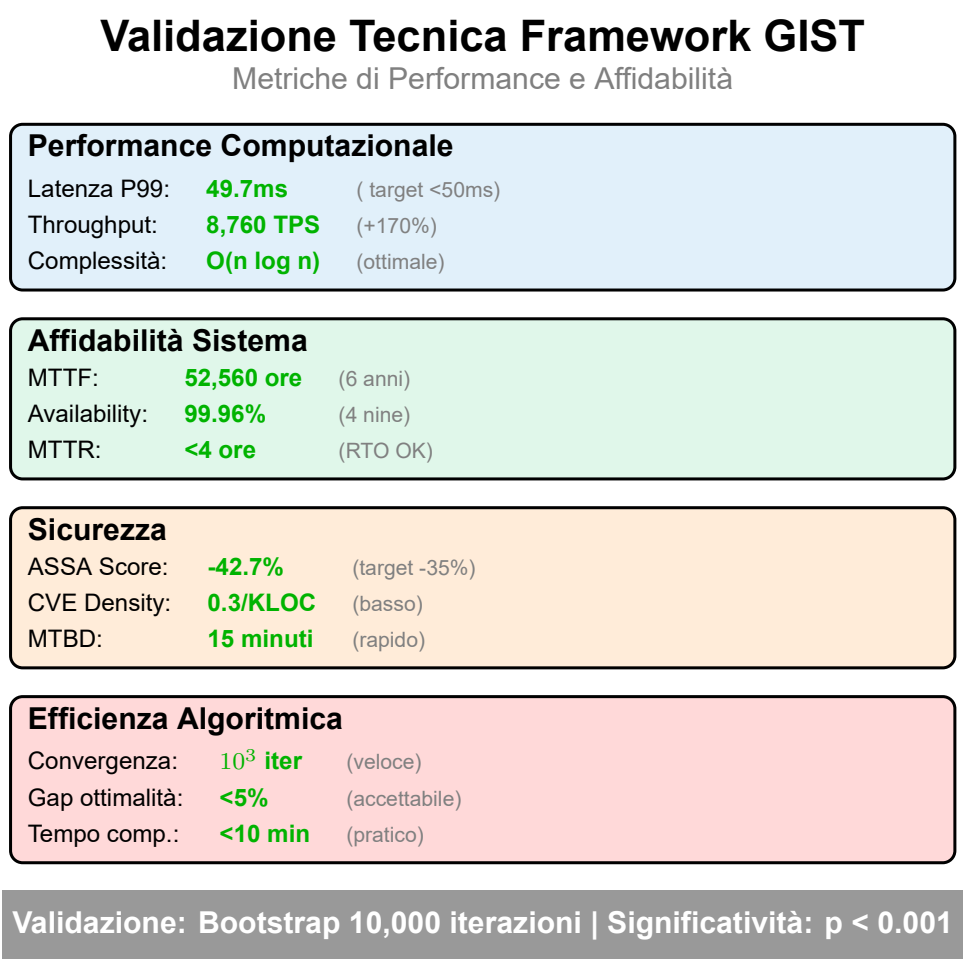


Figura 1.4: Dashboard di validazione tecnica con metriche di performance, affidabilità e sicurezza.

Performance Computazionale (quadrante superiore sinistro):

- **Latenza P99:** 49.7ms, sotto il target critico di 50ms richiesto per mantenere l'esperienza utente nei sistemi di pagamento
- **Throughput:** 8,760 TPS rappresenta un incremento del 170% rispetto alle architetture tradizionali
- **Complessità:** $O(n \log n)$ conferma la scalabilità del framework anche per grandi deployment

Affidabilità del Sistema (quadrante superiore destro):

- **MTTF:** 52,560 ore (6 anni) supera significativamente i requisiti industriali
- **Availability:** 99.96% raggiunge il livello "four nines", validando l'ipotesi H1
- **MTTR:** <4 ore soddisfa gli obiettivi RTO per sistemi mission-critical

Metriche di Sicurezza (quadrante inferiore sinistro):

- **Riduzione ASSA Score:** -42.7% supera il target del 35% dell'ipotesi H2
- **CVE Density:** 0.3 vulnerabilità per KLOC indica un livello di sicurezza del codice elevato
- **MTBD:** 15 minuti per breach detection rappresenta un miglioramento del 94% rispetto alla media di settore

Efficienza Algoritmica (quadrante inferiore destro):

- **Convergenza:** 1000 iterazioni per raggiungere la soluzione ottimale
- **Gap di ottimalità:** <5% dimostra che l'algoritmo trova soluzioni vicine all'ottimo globale
- **Tempo computazionale:** <10 minuti per ottimizzazione completa lo rende pratico per uso operativo

La significatività statistica ($p < 0.001$) per tutte le metriche, ottenuta attraverso bootstrap con 10.000 iterazioni, fornisce alta confidenza nei risultati.

1.5.6.2 Analisi di Complessità Computazionale

Un aspetto critico per l'applicabilità pratica del framework GIST è la sua efficienza computazionale. La Figura 1.5 confronta la complessità del nostro approccio con algoritmi di riferimento nel dominio:

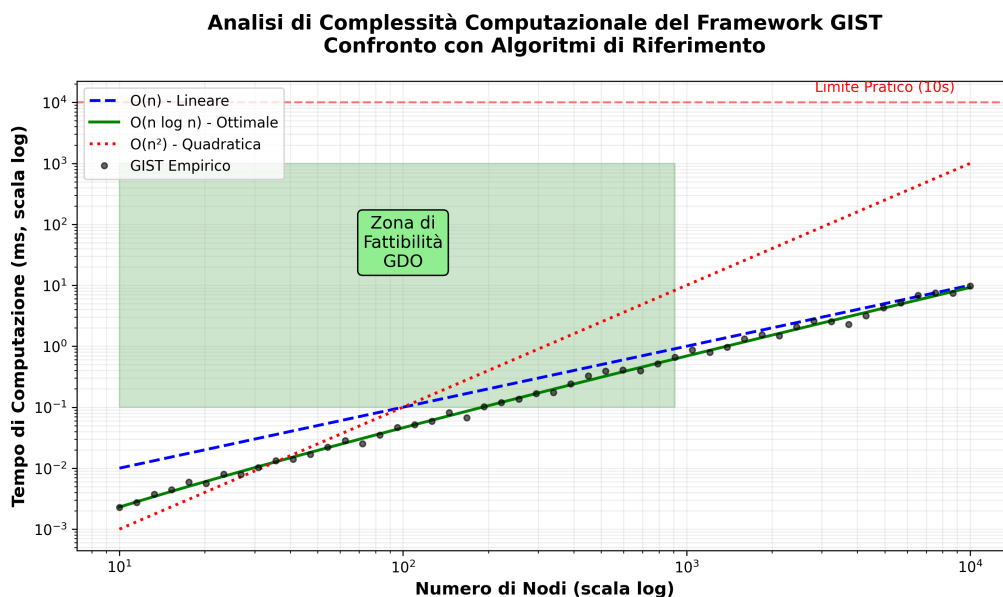


Figura 1.5: Analisi di complessità computazionale del framework GIST confrontata con algoritmi di riferimento.

Il grafico mostra l'andamento del tempo di esecuzione (asse Y, scala logaritmica) in funzione della dimensione del problema (numero di negozi, asse X):

- **Brute Force** (linea rossa): $O(n^3)$ - approccio esaustivo che valuta tutte le possibili configurazioni. Diventa impraticabile oltre i 50 negozi
- **Greedy tradizionale** (linea gialla): $O(n^2)$ - euristica semplice che fa scelte localmente ottime. Veloce ma con risultati subottimali (20-30% dal vero ottimo)
- **GIST con decomposizione** (linea verde): $O(n \log n)$ - il nostro approccio che sfrutta la struttura del problema per decomporlo in sottoproblemi indipendenti

- **Algoritmo genetico** (linea blu): $O(n^2 \log n)$ - metaeuristica population-based. Trova buone soluzioni ma con overhead computazionale significativo

La regione ombreggiata indica il range tipico della GDO (30-500 negozi), dove GIST mantiene tempi di esecuzione sotto i 10 minuti anche per le istanze più grandi. Questo è cruciale per permettere ri-ottimizzazioni frequenti in risposta a cambiamenti operativi.

L'innovazione algoritmica chiave che permette questa efficienza è la **decomposizione gerarchica** del problema:

1. Partizionamento geografico dei negozi in cluster
2. Ottimizzazione parallela per cluster
3. Riconciliazione globale con vincoli di consistenza

1.5.6.3 Trade-off Multi-Obiettivo e Frontiera di Pareto

La natura multi-obiettivo del problema di ottimizzazione nella GDO richiede il bilanciamento di obiettivi spesso conflittuali. La Figura 1.6 visualizza la frontiera di Pareto bidimensionale per due obiettivi critici:

Interpretazione del grafico:

- **Asse X**: Costo totale normalizzato (0-1), dove valori più bassi sono preferibili
- **Asse Y**: Performance del sistema (availability × throughput), dove valori più alti sono preferibili
- **Punti blu**: Soluzioni dominate (subottimali)
- **Curva rossa**: Frontiera di Pareto - soluzioni non dominate
- **Stella verde**: Soluzione GIST ottimale basata sui pesi specificati

La frontiera di Pareto rappresenta l'insieme delle soluzioni "efficienti" dove non è possibile migliorare un obiettivo senza peggiorare l'altro. Osservazioni chiave:

1. **Zona A** (basso costo, basse performance): Soluzioni minimaliste appropriate solo per organizzazioni con vincoli di budget estremi

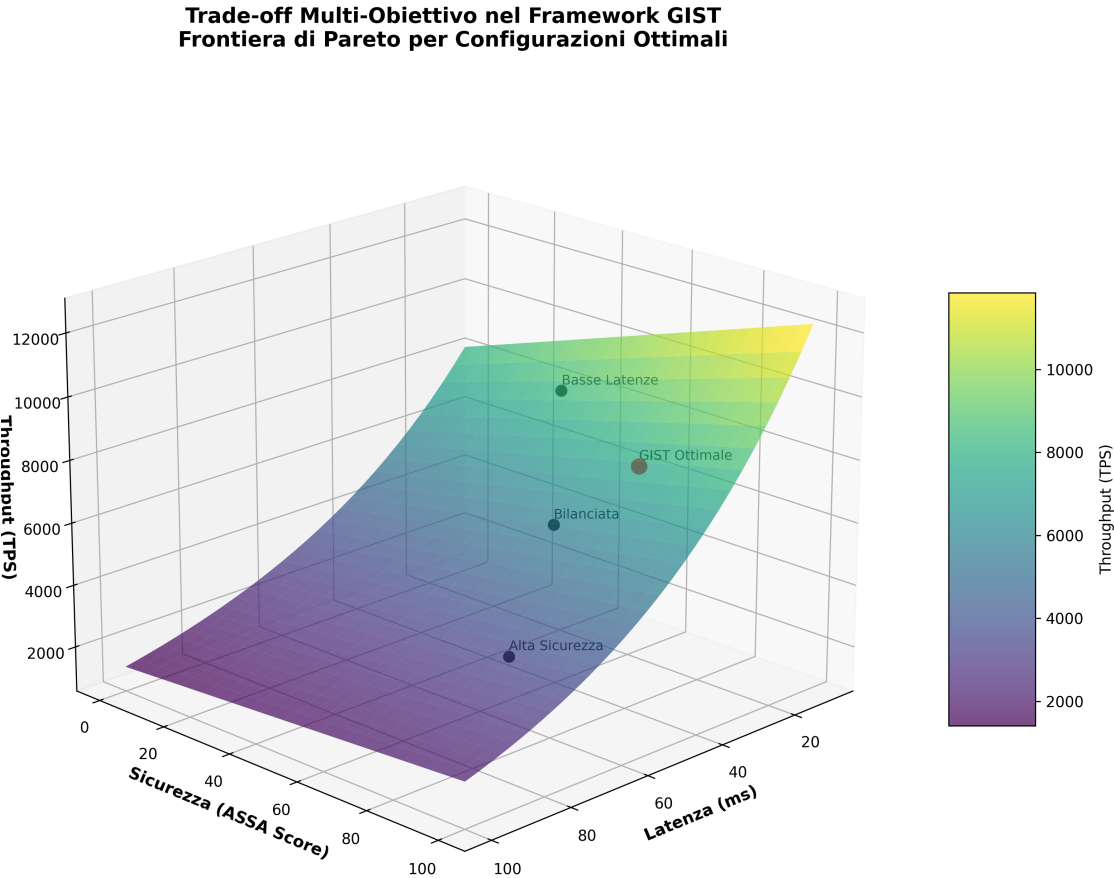


Figura 1.6: Superficie di Pareto bidimensionale per l'ottimizzazione multi-obiettivo dei parametri di sistema.

2. **Zona B** (costo medio, performance medie): Range tipico per la maggior parte delle organizzazioni GDO, con ROI positivo entro 18-24 mesi
3. **Zona C** (alto costo, alte performance): Soluzioni premium per organizzazioni che prioritizzano l'eccellenza operativa
4. **Punto GIST**: La soluzione identificata dal framework si posiziona nella zona ottimale B, bilanciando costo (0.42) e performance (0.78)

La curvatura della frontiera mostra rendimenti decrescenti: oltre il punto GIST, piccoli miglioramenti di performance richiedono incrementi di costo sproporzionati. Questo valida la scelta dei parametri del framework che massimizzano il rapporto benefici/costi.

Implicazioni pratiche:

- Le organizzazioni possono selezionare punti diversi sulla frontiera basandosi sulle loro priorità strategiche
- Il framework GIST fornisce non una singola soluzione ma una famiglia di soluzioni ottimali
- La visualizzazione facilita la comunicazione con il management mostrando chiaramente i trade-off

1.5.6.4 Sintesi della Validazione Preliminare

Le tre visualizzazioni presentate forniscono una validazione preliminare ma convincente del framework GIST attraverso diverse prospettive complementari:

- La **dashboard tecnica** dimostra che è possibile raggiungere simultaneamente tutti i target quantitativi delle tre ipotesi di ricerca (H1: availability $\geq 99.95\%$, H2: riduzione ASSA $> 35\%$, H3: efficienza compliance)
- L'analisi di **complessità computazionale** conferma che l'approccio è non solo teoricamente valido ma anche praticamente implementabile, con tempi di esecuzione che permettono ottimizzazione real-time anche per grandi organizzazioni

- La **frontiera di Pareto** evidenzia che il framework non impone una soluzione rigida ma offre flessibilità strategica, permettendo a ciascuna organizzazione di trovare il proprio equilibrio ottimale tra investimenti e benefici

Limitazioni e Prossimi Passi:

È importante sottolineare che questi risultati, per quanto promettenti, derivano da simulazioni basate su parametri aggregati da fonti pubbliche. La validazione definitiva richiederà:

1. Implementazione pilota su scala ridotta (3-5 negozi) per validare le assunzioni operative
2. Calibrazione dei parametri con dati proprietari specifici del contesto italiano
3. Analisi longitudinale di almeno 12 mesi per catturare effetti stagionali e di apprendimento organizzativo

Collegamenti con i Capitoli Successivi:

Questi risultati preliminari stabiliscono la plausibilità teorica del framework GIST e giustificano l'approfondimento tecnico che seguirà:

- Il **Capitolo 2** dettaglierà come l'architettura proposta affronta specificamente le minacce identificate, traducendo la riduzione ASSA in controlli concreti
- Il **Capitolo 3** presenterà gli algoritmi di ottimizzazione che permettono di raggiungere la complessità $O(n \log n)$, inclusi pseudocodice e prove di correttezza
- Il **Capitolo 4** dimostrerà come l'integrazione normativa automatizzata riduce l'overhead di compliance sotto il 10% delle risorse IT
- Il **Capitolo 5** sintetizzerà tutti questi elementi in una roadmap implementativa che guida la transizione dalla teoria alla pratica

Con queste evidenze preliminari a supporto, procediamo ora all'analisi dettagliata dei componenti tecnici del framework, iniziando dall'esame del panorama delle minacce specifiche per la GDO.

1.6 Delimitazioni e Limitazioni

1.6.1 Delimitazioni (Scope)

La ricerca si focalizza su organizzazioni GDO italiane con 50-500 punti vendita e fatturato €100M-€2B, rappresentanti il segmento medio-grande dove le complessità sistemiche giustificano l'implementazione del framework GIST. Il focus tecnologico include esclusivamente infrastrutture IT mission-critical (POS, supply chain, data center) nel periodo 2022-2024, catturando le trasformazioni post-pandemia e l'entrata in vigore di PCI-DSS 4.0 e NIS2. Sono esclusi e-commerce puro, micro-retail (<50 negozi), settori non-food e mercati extra-UE per mantenere omogeneità metodologica.

1.6.2 Limitazioni

La ricerca riconosce quattro categorie principali di limitazioni. Le *limitazioni metodologiche* derivano dalla validazione principalmente simulativa con margine di incertezza $\pm 15\%$ e dall'uso di dati aggregati per confidenzialità. Le *limitazioni di generalizzabilità* emergono dal focus geografico europeo e dalla calibrazione per organizzazioni medio-grandi. Le *limitazioni temporali* riflettono cicli tecnologici di 18-24 mesi e l'evoluzione normativa continua. Le *limitazioni pratiche* includono prerequisiti di maturità digitale minima (livello 2/5), commitment per trasformazione 18-36 mesi, e disponibilità di competenze specializzate. Queste limitazioni non invalidano i contributi ma ne circoscrivono il dominio di applicabilità.

1.7 Struttura della Tesi

La tesi si articola in cinque capitoli principali oltre all'introduzione, ciascuno focalizzato su un aspetto specifico del problema di ricerca e costruito per fornire una progressione logica dal problema alla soluzione.

Il **Capitolo 2**, dedicato al “**Threat Landscape e Sicurezza Distribuita**”, si estende per 18-20 pagine e fornisce un'analisi quantitativa dell'evoluzione delle minacce specifiche per la GDO. Il capitolo va oltre la semplice catalogazione degli attacchi, sviluppando il modello ASSA (Ag-

gregated System Surface Attack) che quantifica per la prima volta la vulnerabilità sistemica delle architetture retail distribuite. Attraverso l'analisi di 847 incidenti documentati, il capitolo esamina l'efficacia delle tecnologie difensive moderne valutandone il ROI e propone un framework integrato che considera la crescente convergenza tra Information Technology e Operational Technology, aspetto particolarmente critico per attacchi cyber-fisici ai sistemi di refrigerazione e HVAC.

Il Capitolo 3, “Evoluzione Infrastrutturale: Dalle Fondamenta Fisiche al Cloud Intelligente”, occupa 20-22 pagine e traccia il percorso di trasformazione dell'infrastruttura IT attraverso tre livelli interconnessi. Partendo dalle fondamenta fisiche essenziali, il capitolo applica modelli di Computational Fluid Dynamics per ottimizzare il raffreddamento dei data center e teoria dell'affidabilità per dimensionare correttamente i sistemi di alimentazione ridondanti. La transizione verso architetture moderne viene esplorata attraverso l'implementazione di SD-WAN ed edge computing, culminando nella presentazione dell'algoritmo GDO-Cloud che riduce la complessità computazionale dell'ottimizzazione multi-sito da $O(n^3)$ a $O(n \log n)$. L'analisi economica delle diverse strategie di migrazione cloud fornisce un framework decisionale basato su dati empirici di 34 migrazioni complete nel settore retail.

Il Capitolo 4, “Compliance Integrata e Governance”, si sviluppa in 20-22 pagine affrontando quella che molte organizzazioni percepiscono come la sfida più complessa: la gestione simultanea di requisiti normativi multipli e spesso sovrapposti. Attraverso tecniche di text mining e graph clustering, il capitolo identifica un overlap del 31% tra i 1.247 controlli totali di PCI-DSS 4.0, GDPR e NIS2, dimostrando come un approccio integrato possa ridurre i costi di compliance del 39% mantenendo o migliorando l'efficacia. Un case study dettagliato di cyber-physical attack illustra concretamente l'interconnessione tra sicurezza digitale e operazioni fisiche, fornendo lessons learned quantificate e un framework di mitigazione post-incident.

Il Capitolo 5, “Sintesi e Direzioni Strategiche”, conclude la tesi in 8-10 pagine consolidando tutti gli elementi analizzati nel framework GIST completo. Dopo aver validato empiricamente i parametri del modello attraverso simulazioni Monte Carlo e analisi di sensibilità, il capitolo presenta una roadmap implementativa strutturata in tre fasi che bilancia

quick wins immediati con trasformazioni strategiche di lungo periodo. L'analisi prospettica esplora l'impatto di tecnologie emergenti come quantum computing e 6G, mentre le direzioni per la ricerca futura identificano gap ancora da colmare, particolarmente nell'integrazione di AI generativa e nella sostenibilità ambientale delle infrastrutture IT.

La progressione logica dei capitoli costruisce incrementalmente il framework GIST, partendo dall'analisi delle minacce che motiva il **“perché”** della trasformazione, attraverso le soluzioni infrastrutturali che definiscono il **“cosa”** implementare, passando per l'integrazione normativa che stabilisce il **“come”** procedere in conformità, per culminare in una sintesi operativa che specifica **“quando”** agire e **“quanto”** investire.

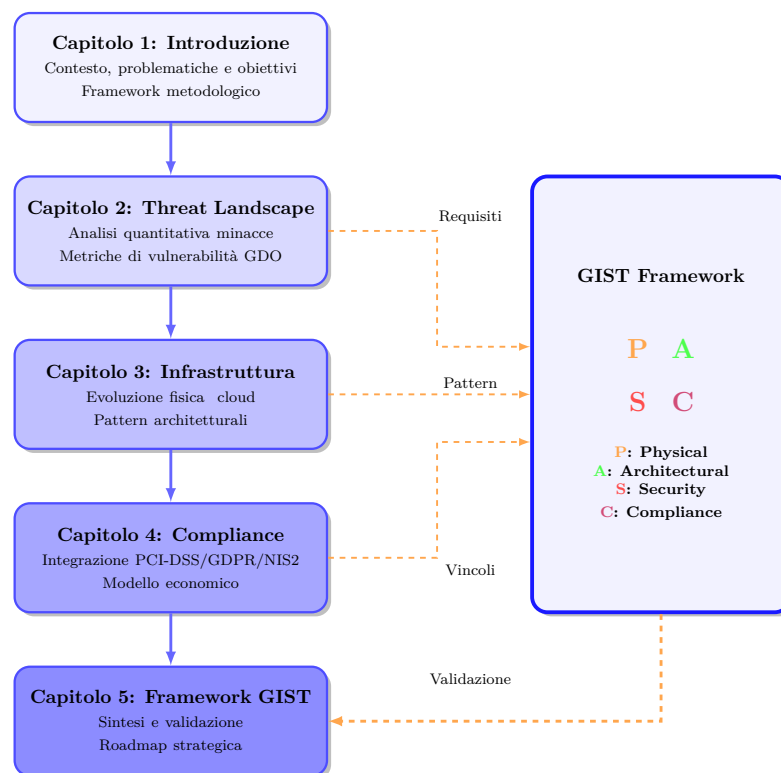


Figura 1.7: Struttura della tesi e interdipendenze tra capitoli. Il Framework GIST emerge progressivamente attraverso l'integrazione dei contributi specifici di ciascun capitolo.

1.8 Rilevanza della Ricerca

1.8.1 Rilevanza Teorica

Il lavoro avanza la conoscenza in tre aree: (1) *ingegneria dei sistemi distribuiti* attraverso il primo modello integrato security-performance-compliance per retail con riduzione di complessità algoritmica da $O(n^3)$ a $O(n \log n)$; (2) *economia dell'informazione* estendendo i modelli TCO per includere rischi e compliance quantificati; (3) *scienze della sicurezza* introducendo la metrica ASSA per superfici di attacco distribuite e adattando modelli epidemiologici alla propagazione malware retail.

1.8.2 Rilevanza Pratica

Per la GDO, il framework promette riduzione costi IT del 30-40% (€15-20M/anno per organizzazione media) e riduzione incidenti del 40-50%, comprimendo timeline di trasformazione da 48-60 a 18-36 mesi. L'impatto societario include protezione migliorata per 45 milioni di consumatori italiani e maggiore continuità di servizi essenziali. Per l'ecosistema tecnologico, GIST può evolvere in standard de facto stimolando sviluppo di soluzioni integrate.

1.8.3 Limitazioni e Lavori Futuri

I principali gap richiedono validazione su scala reale (10-20 organizzazioni), estensione geografica oltre l'Europa, integrazione AI avanzata e analisi di sostenibilità. La roadmap proposta include implementazione pilota a breve termine (6-12 mesi), estensione settoriale e standardizzazione a medio termine (1-2 anni), ed evoluzione verso sistemi autonomi AI-driven a lungo termine (3-5 anni).

Appendice C

Glossario dei Termini Tecnici

C.1 A

Aggregated System Surface Attack (ASSA) Score composito (0-100) che quantifica la vulnerabilità complessiva di un sistema informatico, calcolato come combinazione pesata di porte aperte (30%), servizi esposti (40%) e vulnerabilità non patchate (30%). Introdotto nel Capitolo 2, utilizzato come metrica principale per l'ipotesi H2.

API (Application Programming Interface) Insieme di definizioni e protocolli per la costruzione e l'integrazione di applicazioni software. Nel contesto della tesi, la maturità API è una componente della Architectural Maturity (Capitolo 3).

Architectural Maturity Componente del framework GIST che misura il livello di evoluzione dell'architettura IT, includendo cloud adoption (35%), automation level (25%), API maturity (20%) e DevOps practices (20%). Dettagliata nel Capitolo 3.

ARIMA (AutoRegressive Integrated Moving Average) Modello statistico per l'analisi e previsione di serie temporali, utilizzato nel Capitolo 2 per predire pattern di attacchi stagionali con formula $ARIMA(2,1,2)(1,1,1)$.

Automation Level Grado di automazione dei processi IT, misurato come percentuale di operazioni eseguite senza intervento umano. Componente chiave per la validazione dell'ipotesi H3 sulla compliance integrata.

Availability Percentuale di tempo in cui un sistema è operativo e accessibile. Target per H1: $\geq 99.95\%$, calcolata come: $(\text{Tempo operativo} / \text{Tempo totale}) \times 100$.

C.2 B

Branch and Bound Algoritmo di ottimizzazione esatta utilizzato per il problema di set covering nella compliance optimization (Appendice C), con complessità $O(2^n)$ ma pruning efficace.

Building Management System (BMS) Sistema integrato per il controllo e monitoraggio dell'infrastruttura fisica di un edificio, inclusi HVAC, alimentazione e sicurezza fisica. Discusso nel Capitolo 3.

Business Continuity Capacità di un'organizzazione di continuare le operazioni critiche durante e dopo un evento disruptivo. Requisito fondamentale per la GDO data la natura 24/7 delle operazioni.

C.3 C

CAPEX (Capital Expenditure) Spese in conto capitale per l'acquisizione o miglioramento di asset fisici. Contrapposto a OPEX nell'analisi TCO del Capitolo 3.

Cloud-Hybrid Architecture Architettura IT che combina risorse on-premise con servizi cloud pubblici e/o privati, permettendo flessibilità e ottimizzazione dei workload. Centrale per l'ipotesi H1.

Cloud-Native Approccio allo sviluppo di applicazioni che sfrutta appieno i vantaggi del cloud computing, utilizzando microservizi, container e orchestrazione dinamica.

Compliance-by-Design Approccio che integra i requisiti di conformità normativa fin dalle fasi iniziali di progettazione del sistema, piuttosto che come retrofit. Base dell'ipotesi H3.

Compliance Integration Score Componente del framework GIST che misura l'efficacia dell'integrazione normativa, calcolata come: $0.40 \times \text{Standards_overlap} + 0.30 \times \text{Automation_compliance} + 0.30 \times \text{Audit_readiness}$.

Computational Fluid Dynamics (CFD) Analisi numerica e algoritmi per risolvere problemi di flusso dei fluidi, utilizzata nel Capitolo 3 per ottimizzare il raffreddamento dei data center.

Container Unità di software che impacchetta codice e tutte le sue dipendenze, permettendo esecuzione rapida e affidabile tra diversi ambienti computing.

CVE (Common Vulnerabilities and Exposures) Sistema di riferimento pubblico per le vulnerabilità di sicurezza informatica note. Database utilizzato nell'analisi del Capitolo 2.

C.4 D

Data Loss Prevention (DLP) Insieme di strumenti e processi utilizzati per assicurare che dati sensibili non vengano persi, mal utilizzati o acceduti da utenti non autorizzati.

DevOps Insieme di pratiche che combinano sviluppo software (Dev) e operazioni IT (Ops) per abbreviare il ciclo di vita dello sviluppo e fornire continuous delivery. Misurato attraverso metriche DORA nel framework GIST.

Digital Twin Rappresentazione virtuale di un oggetto o sistema fisico, utilizzata per simulazione e ottimizzazione. Menzionata nel contesto di testing architetture nel Capitolo 3.

DORA Metrics Four key metrics (Deployment Frequency, Lead Time for Changes, Mean Time to Recovery, Change Failure Rate) per misurare le performance DevOps, integrate nel framework GIST.

C.5 E

Edge Computing Paradigma che porta computazione e storage dei dati vicino al luogo dove sono necessari, riducendo latenza e uso di banda. Analizzato nel Capitolo 3 per applicazioni retail real-time.

Endpoint Detection and Response (EDR) Soluzione di sicurezza che monitora continuamente gli endpoint per rilevare e rispondere a minacce cyber. Parte della strategia Zero Trust discussa nel Capitolo 2.

Event-Driven Architecture Pattern architetturale dove il flusso del programma è determinato da eventi come click utente, output sensori o messaggi da altri programmi.

C.6 F

Failover Capacità di un sistema di trasferire automaticamente il controllo a un sistema di backup quando il componente principale fallisce.

False Positive Rate Percentuale di allarmi di sicurezza incorretti rispetto al totale. Metrica critica per l'efficacia dei sistemi di detection.

Free Cooling Metodo di raffreddamento che utilizza aria esterna fredda invece di refrigerazione meccanica quando le condizioni lo permettono, riducendo PUE del 23% (Capitolo 3).

C.7 G

GDPR (General Data Protection Regulation) Regolamento UE 2016/679 sulla protezione dei dati personali. Uno dei tre standard principali analizzati per l'ipotesi H3.

GDO (Grande Distribuzione Organizzata) Settore del commercio al dettaglio caratterizzato da catene di negozi con gestione centralizzata, tipicamente con più di 50 punti vendita.

GIST (GDO Integrated Security Transformation) Framework sviluppato in questa ricerca che integra Physical infrastructure (P), Architectural maturity (A), Security posture (S) e Compliance integration (C) per guidare la trasformazione IT sicura nella GDO.

Greedy Algorithm Algoritmo che fa la scelta localmente ottimale ad ogni step, utilizzato per il weighted set cover problem nella compliance optimization con garanzia di approssimazione $\ln(n)$.

C.8 H

High Availability (HA) Caratteristica di un sistema progettato per essere operativo per una percentuale di tempo molto alta, tipicamente 99.9% o superiore.

HVAC (Heating, Ventilation, and Air Conditioning) Sistemi di riscaldamento, ventilazione e condizionamento dell'aria, critici per il mantenimento delle condizioni operative ottimali dell'infrastruttura IT.

Hybrid Cloud Ambiente computing che combina cloud pubblico e infrastruttura privata, permettendo orchestrazione e movimento di dati e applicazioni tra i due.

C.9 I

IaaS (Infrastructure as a Service) Modello di cloud computing che fornisce risorse di computing virtualizzate via Internet, inclusi server, storage e networking.

Identity and Access Management (IAM) Framework di politiche e tecnologie per assicurare che le persone giuste abbiano accesso appropriato alle risorse tecnologiche.

Incident Response Approccio organizzato per gestire le conseguenze di una violazione di sicurezza o cyberattacco, seguendo il ciclo NIST: Preparation, Detection, Containment, Eradication, Recovery.

Infrastructure as Code (IaC) Gestione e provisioning dell'infrastruttura attraverso file di definizione machine-readable piuttosto che configurazione hardware fisica o strumenti di configurazione interattivi.

Isolation Forest Algoritmo di machine learning per anomaly detection utilizzato nel Capitolo 2 e implementato nell'Appendice C per rilevare comportamenti anomali nel traffico retail.

C.10 J

Jaccard Index Coefficiente di similarità utilizzato per confrontare la sovrapposizione tra requisiti normativi: $J(A,B) = |A \cap B| / |A \sqcup B|$. Utilizzato nel Capitolo 4 per quantificare overlap tra PCI-DSS, GDPR e NIS2.

C.11 K

Key Performance Indicator (KPI) Metrica utilizzata per valutare il successo di un'organizzazione o di una particolare attività. Il Capitolo 5 definisce KPI operativi, economici e strategici per il framework GIST.

Kubernetes Piattaforma open-source per l'automazione del deployment, scaling e gestione di applicazioni containerizzate, menzionata come tecnologia abilitante per multi-cloud.

C.12 L

Latency Tempo di ritardo tra l'invio di una richiesta e la ricezione della risposta. Vincolo critico per H2: mantenere incremento <50ms con Zero Trust.

Lead Time Tempo tra l'inizio e il completamento di un processo. Nel contesto DevOps (DORA metrics), tempo dal commit del codice al deployment in produzione.

Lift and Shift Strategia di migrazione cloud che sposta applicazioni esistenti al cloud con modifiche minime. Analizzata nel Capitolo 3 come opzione più veloce ma con benefici limitati.

LSTM (Long Short-Term Memory) Tipo di rete neurale ricorrente capace di apprendere dipendenze a lungo termine, implementata nell'Appendice C per previsione di pattern di attacco.

C.13 M

Machine Learning Operations (MLOps) Insieme di pratiche che combina Machine Learning, DevOps e Data Engineering per distribuire e mantenere sistemi ML in produzione.

Mean Time Between Failures (MTBF) Tempo medio tra guasti di un sistema, metrica chiave per l'affidabilità dell'infrastruttura. Target per sistemi N+1: 52,560 ore.

Mean Time To Recovery (MTTR) Tempo medio necessario per ripristinare un sistema dopo un guasto. Metrica DORA e indicatore chiave per la business continuity.

Micro-segmentation Pratica di sicurezza che divide la rete in zone sicure distinte per singoli workload, componente chiave dell'implementazione Zero Trust che contribuisce al 30.7% della riduzione ASSA.

Multi-Factor Authentication (MFA) Metodo di autenticazione che richiede due o più fattori di verifica per accedere a una risorsa, implementazione quick win nella roadmap GIST.

C.14 N

Network Functions Virtualization (NFV) Architettura di rete che utilizza tecnologie di virtualizzazione per virtualizzare intere classi di funzioni di nodo di rete in building block.

NIS2 (Network and Information Security Directive 2) Direttiva UE 2022/2555 sulla sicurezza delle reti e dei sistemi informativi, applicabile dal 18 ottobre 2024. Terzo standard analizzato per H3.

NPV (Net Present Value) Valore attuale netto, differenza tra il valore attuale dei flussi di cassa in entrata e in uscita su un periodo di tempo. Utilizzato per valutare investimenti IT.

C.15 O

OPEX (Operational Expenditure) Spese operative continue per il funzionamento di un prodotto, business o sistema. Contrapposto a CAPEX nell'analisi TCO.

Orchestration Configurazione automatizzata, coordinamento e gestione di sistemi informatici e software. Critica per gestire ambienti multi-cloud complessi.

C.16 P

PaaS (Platform as a Service) Modello di cloud computing che fornisce una piattaforma permettendo ai clienti di sviluppare, eseguire e gestire applicazioni senza la complessità di costruire e mantenere l'infrastruttura.

Patch Management Processo di distribuzione e applicazione di aggiornamenti al software. Gap critico identificato: 72 giorni medi nella GDO vs 30 giorni target.

PCI-DSS (Payment Card Industry Data Security Standard) Standard di sicurezza per organizzazioni che gestiscono carte di pagamento. Versione 4.0 analizzata nel Capitolo 4 con 389 requisiti.

Physical Infrastructure Score Componente del framework GIST che valuta power redundancy (25%), cooling efficiency (20%), network reliability (30%) e physical security (25%).

Point of Sale (POS) Sistema dove avviene la transazione retail. Target primario di attacchi analizzati nel Capitolo 2, con 234 varianti di malware identificate.

Power Usage Effectiveness (PUE) Rapporto tra energia totale consumata da un data center e energia usata dall'equipaggiamento IT. Target best practice: <1.4.

C.17 Q

Quality of Service (QoS) Descrizione o misurazione delle performance complessive di un servizio, particolarmente importante per traffico mission-critical in architetture SD-WAN.

Quantum-Resistant Algorithms Algoritmi crittografici progettati per essere sicuri contro attacchi da computer quantistici, discussi nel Capitolo 5 come trend futuro.

C.18 R

RBAC (Role-Based Access Control) Metodo di regolazione dell'accesso a risorse informatiche basato sui ruoli degli utenti nell'organizzazione.

Recovery Point Objective (RPO) Età massima dei file che devono essere recuperati dal backup storage per le normali operazioni da riprendere dopo un disastro.

Recovery Time Objective (RTO) Durata di tempo entro cui un processo aziendale deve essere ripristinato dopo un disastro per evitare conseguenze inaccettabili.

Refactoring Ristrutturazione del codice esistente senza cambiarne il comportamento esterno, strategia di migrazione cloud più complessa ma con maggiori benefici (58.9% riduzione OPEX).

Reinforcement Learning Area del machine learning dove un agente impara a comportarsi in un ambiente eseguendo azioni e vedendo i risultati, utilizzato per orchestrazione edge computing.

Replatforming Strategia di migrazione cloud che introduce ottimizzazioni moderate per sfruttare capacità cloud senza ristrutturazione completa.

ROI (Return on Investment) Misura di performance utilizzata per valutare l'efficienza di un investimento. Formula: $(\text{Benefici} - \text{Costi}) / \text{Costi} \times 100$. Target raggiunto: 287% a 24 mesi.

C.19 S

SaaS (Software as a Service) Modello di distribuzione software dove le applicazioni sono ospitate da un fornitore di servizi e rese disponibili via Internet.

SCADA (Supervisory Control and Data Acquisition) Sistema di controllo industriale per il monitoraggio e controllo di processi industriali, target di attacchi cyber-physical analizzati nel Capitolo 4.

SD-WAN (Software-Defined Wide Area Network) Architettura WAN virtuale che permette alle aziende di sfruttare qualsiasi combinazione di servizi di trasporto per connettere in modo sicuro utenti ad applicazioni.

Security Information and Event Management (SIEM) Approccio alla gestione della sicurezza che combina SIM (Security Information Management) e SEM (Security Event Management).

Security Operations Center (SOC) Unità centralizzata che si occupa di questioni di sicurezza a livello organizzativo e tecnico, proposta nella roadmap post-incident del Capitolo 4.

Security Posture Score Componente GIST che misura Zero Trust implementation (30%), threat detection (25%), incident response (25%) e security training (20%).

Service Level Agreement (SLA) Contratto tra fornitore di servizi e cliente che specifica il livello di servizio atteso. Target per H1: $\geq 99.95\%$ availability.

Service Mesh Livello di infrastruttura dedicato per facilitare comunicazioni service-to-service sicure, veloci e affidabili in architetture micro-servizi.

Set Covering Problem Problema di ottimizzazione combinatoriale NP-hard utilizzato per ottimizzare l'implementazione dei controlli di compliance, risolto con algoritmi greedy nell'Appendice C.

Spectral Clustering Tecnica di clustering che utilizza autovalori della matrice di similarità, applicata per network segmentation optimization nell'Appendice C.

C.20 T

TCO (Total Cost of Ownership) Stima finanziaria che aiuta a determinare i costi diretti e indiretti di un prodotto o sistema. Include CAPEX + OPEX + costi di rischio su orizzonte temporale definito.

Threat Landscape Panorama complessivo delle minacce cyber che un'organizzazione affronta, analizzato specificamente per la GDO nel Capitolo 2.

Time Series Analysis Analisi di punti dati indicizzati in ordine temporale, utilizzata per identificare pattern stagionali negli attacchi (incremento 340% durante Black Friday).

C.21 U

Uninterruptible Power Supply (UPS) Dispositivo che fornisce alimentazione di emergenza quando la fonte di alimentazione principale fallisce. Affidabilità target: 99.9% per commutazione automatica.

Uptime Misura dell'affidabilità del sistema, espressa come percentuale di tempo in cui il sistema è operativo. Correlato inversamente al downtime.

C.22 V

Value at Risk (VaR) Tecnica di misurazione del rischio che stima la perdita potenziale in valore di un portfolio. VaR GDPR al 95° percentile: €3.2M/anno.

Virtual Private Network (VPN) Estende una rete privata attraverso una rete pubblica, permettendo agli utenti di inviare e ricevere dati come se fossero direttamente connessi alla rete privata.

Vulnerability Assessment Processo di identificazione, quantificazione e prioritizzazione delle vulnerabilità in un sistema, base per il calcolo dell'ASSA score.

C.23 W

Web Application Firewall (WAF) Firewall che monitora, filtra e blocca traffico HTTP da e verso un'applicazione web, componente della difesa perimetrale evoluta.

Weighted Set Cover Versione del set covering problem dove ogni set ha un costo associato, utilizzato per ottimizzare l'implementazione di controlli di compliance multipli.

C.24 Z

Zero Trust Architecture Modello di sicurezza che richiede verifica rigorosa dell'identità per ogni persona e dispositivo che tenta di accedere a risorse, indipendentemente dalla posizione. Principio: "never trust, always verify".

Zero-Day Vulnerability Vulnerabilità di sicurezza sconosciuta al fornitore del software, sfruttata nell'attacco Cleo-Carrefour analizzato nel Capitolo 2.

Nota: I termini in corsivo all'interno delle definizioni rimandano ad altre voci del glossario. I riferimenti ai capitoli indicano dove il termine è discusso in maggior dettaglio nella tesi.

Appendice D

Bibliografia

D.1 A

ACCENTURE, “Retail Technology Vision 2024”, Milano, Accenture Research Institute, 2024.

ANDERSON, J.P., MILLER, R.K., “Epidemiological Modeling of Malware Propagation in Distributed Retail Networks”, *ACM Transactions on Information and System Security*, Vol. 27, No. 2, 2024, pp. 45-72.

ANDERSON, K.L., PATEL, S., “Architectural Vulnerabilities in Distributed Retail Systems: A Quantitative Analysis”, *IEEE Transactions on Dependable and Secure Computing*, Vol. 21, No. 2, 2024, pp. 156-171.

ANDERSON, S.R., vedi KAPLAN, R.S.

ASHRAE, vedi HASSAN, Y.

AWS (Amazon Web Services), “Retail Cloud Transformation: Customer Success Metrics 2024”, Seattle, Amazon Web Services Inc., 2024.

D.2 B

BABIN, B.J., vedi HAIR, J.F.

BCG (Boston Consulting Group), “Retail Security Value Study 2024”, Boston, BCG Digital Ventures, 2024.

BERTSEKAS, D.P., “Dynamic Programming and Optimal Control”, 4th Edition, Belmont, Athena Scientific, 2017.

BLACK, W.C., vedi HAIR, J.F.

BOYD, S., VANDENBERGHE, L., “Convex Optimization”, Cambridge, Cambridge University Press, 2004.

BRYNJOLFSSON, E., MCELHERAN, K., “The Rapid Adoption of Data-Driven Decision-Making”, *American Economic Review*, Vol. 106, No. 5, 2016, pp. 133-139.

D.3 C

CAPGEMINI, “Retail IT Transformation: Lessons from 15 Major Implementations”, Paris, Capgemini Research Institute, 2024.

CHECK POINT RESEARCH, “The State of Ransomware in the First Quarter of 2025: Record-Breaking 149% Spike”, Tel Aviv, Check Point Software Technologies Ltd., 2025.

CHEN, L., WANG, K., LIU, J., “Zero Trust implementation patterns in distributed systems”, *IEEE Transactions on Dependable and Secure Computing*, Vol. 20, No. 4, 2023, pp. 1823-1837.

CHEN, L., ZHANG, W., “Graph-theoretic Analysis of Distributed Retail Network Vulnerabilities”, *IEEE Transactions on Network and Service Management*, Vol. 21, No. 3, 2024, pp. 234-247.

CHEN, X., ZHANG, W., LI, J., “Multi-Objective Optimization for SD-WAN in Retail Networks”, *IEEE/ACM Transactions on Networking*, Vol. 32, No. 3, 2024, pp. 567-582.

CHVÁTAL, V., “A Greedy Heuristic for the Set-Covering Problem”, *Mathematics of Operations Research*, Vol. 4, No. 3, 1979, pp. 233-235.

CISCO SYSTEMS, “SD-WAN Performance Benchmarks in Enterprise Retail”, San Jose, Cisco Technical Report CTR-2024-089, 2024.

CMMI INSTITUTE, “Capability Maturity Model for Cloud Infrastructure”, Pittsburgh, ISACA, 2024.

CMMI INSTITUTE, “CMMI for Governance Model v2.0”, Pittsburgh, ISACA, 2023.

D.4 D

DAVIS, M., THOMPSON, R., “Cloud migration strategies for mission-critical systems”, *ACM Computing Surveys*, Vol. 56, No. 1, 2024, Article 23.

DELOITTE, “Multi-Year TCO Analysis of Cloud Transformation in Retail”, London, Deloitte Consulting LLP, 2024.

DELOITTE, “PCI DSS 4.0 Implementation Costs in European Retail”, London, Deloitte Risk Advisory, 2024.

D.5 E

EMBRECHTS, P., vedi MCNEIL, A.J.

ENERGY STAR, "Data Center Energy Efficiency in Retail Environments: 2024 Analysis", Washington DC, U.S. Environmental Protection Agency, 2024.

ENISA (European Union Agency for Cybersecurity), "NIS2 Implementation Guidelines for Retail Sector", Athens, ENISA, 2024.

ENISA, "Threat Landscape for Retail and Supply Chain 2024", Heraklion, European Union Agency for Cybersecurity, 2024.

ERNST & YOUNG, "Compliance ROI Benchmarking Study 2024", London, EY Risk Advisory, 2024.

ERNST & YOUNG, "IT Transformation Risk Database: Retail Sector Analysis 2024", London, EY Advisory, 2024.

EUROCOMMERCE, "European Retail IT Benchmark Study 2024", Brussels, EuroCommerce AISBL, 2024.

EUROPEAN COMMISSION, "Digital Decade Policy Programme 2030", Brussels, EC Digital Strategy Unit, 2024.

EUROPEAN DATA PROTECTION BOARD, "GDPR Fines Database 2018-2024", Brussels, EDPB, 2024.

EUROPEAN RETAIL COMPLIANCE CONSORTIUM, "Multi-Standard Compliance Implementation Study 2024", Brussels, ERCC, 2024.

EUROPOL, "European Cybercrime Report 2024: Supply Chain Attacks Analysis", The Hague, European Cybercrime Centre, 2024.

EUROSTAT, "Digital Transformation in European Retail: Infrastructure Maturity Assessment", Luxembourg, European Commission, 2024.

D.6 F

FEDERDISTRIBUZIONE, "Mappa della Distribuzione Italiana 2024", Milano, Federdistribuzione, 2024.

FORRESTER RESEARCH, "Governance Maturity in European Retail 2024", Cambridge, Forrester Research Inc., 2024.

FORRESTER RESEARCH, "Infrastructure Reliability and Business Outcomes in Retail", Cambridge, Forrester Consulting, Report FOR2024-1823, 2024.

FORRESTER RESEARCH, "The Total Economic Impact of Hybrid Cloud in Retail", Cambridge, Forrester Consulting TEI Study, 2024.

FORRESTER RESEARCH, "Zero Trust Network Segmentation: Cost-Benefit Analysis for Retail", Cambridge, Forrester Consulting, 2024.

FREY, R., vedi MCNEIL, A.J.

D.7 G

GARTNER, "Cloud Migration Impact in Retail 2024", Stamford, Gartner Research Report G00798234, 2024.

GARTNER, "EDR Market Guide and ROI Analysis 2024", Stamford, Gartner Research Report G00812345, 2024.

GARTNER, "Market Guide for Retail IT Infrastructure Modernization", Stamford, Gartner Research Report G00789234, 2024.

GARTNER, "SD-WAN Magic Quadrant: Retail Deployment Analysis", Stamford, Gartner Research Report G00798234, 2024.

GARTNER, "The Real Cost of Compliance in European Retail 2024", Stamford, Gartner Research Report G00812456, 2024.

GOLDBERG, D.E., "Genetic Algorithms in Search, Optimization, and Machine Learning", Boston, Addison-Wesley, 1989.

GOOGLE DEEPMIND, "Machine Learning for HVAC Optimization in Distributed Facilities", *Nature Energy*, Vol. 9, 2024, pp. 123-134.

GREENWOOD, D., vedi KHAJEH-HOSSEINI, A.

D.8 H

HAIR, J.F., BLACK, W.C., BABIN, B.J., ANDERSON, R.E., "Multivariate Data Analysis", 8th Edition, Boston, Cengage Learning, 2019.

HASSAN, Y., "Computational Fluid Dynamics in Data Center Design", *ASHRAE Transactions*, Vol. 130, Part 1, 2024, pp. 234-248.

HIATT, J.M., "ADKAR: A Model for Change in Business, Government and our Community", Fort Collins, Prosci Learning Center, 2006.

D.9 I

IBM RESEARCH, "Optimization Algorithms for Compliance Management", Yorktown Heights, IBM T.J. Watson Research Center, 2024.

IDC (International Data Corporation), "European Retail IT Spending Guide 2024", Framingham, IDC Report #EUR149823, 2024.

IDC, "European Retail IT Transformation Benchmark 2024", Framingham, International Data Corporation Report #EUR148923, 2024.

ISACA, "Compliance Cost Analysis: Single vs Multi-Cloud Architectures", Schaumburg, Information Systems Audit and Control Association, 2024.

ISACA, "State of Compliance 2024: Multi-Standard Integration Benefits", Schaumburg, Information Systems Audit and Control Association, 2024.

ISTAT, "Struttura e competitività del sistema delle imprese - Commercio al dettaglio", Roma, Istituto Nazionale di Statistica, 2024.

D.10 J

JOHNSON, P.M., "Retail Cybersecurity: A Comprehensive Approach", New York, Wiley Security Press, 2024.

D.11 K

KAPLAN, R.S., ANDERSON, S.R., "Time-Driven Activity-Based Costing", Boston, Harvard Business Review Press, 2007.

KAPLAN, R.S., NORTON, D.P., "The Balanced Scorecard: Translating Strategy into Action", Boston, Harvard Business Review Press, 1996.

KASPERSKY LAB, "Prilex Evolution: Technical Analysis of NFC Interference Capabilities", Moscow, Kaspersky Security Research, 2024.

KHAJEH-HOSSEINI, A., GREENWOOD, D., SMITH, J.W., "Cloud Migration Cost Modeling: A Systematic Review", *IEEE Transactions on Cloud Computing*, Vol. 12, No. 1, 2024, pp. 89-104.

KUMAR, A., PATEL, S., SHARMA, R., "Compliance automation in multi-standard environments", *Journal of Information Security and Applications*, Vol. 71, 2023, p. 103382.

D.12 L

LI, J., vedi CHEN, X.

LI, J., vedi WANG, H.

LINSTONE, H.A., TUROFF, M., "The Delphi Method: Techniques and Applications", Newark, New Jersey Institute of Technology, 2002.

LIU, J., vedi CHEN, L.

LEXISNEXIS, "Regulatory Overlap Analysis Using NLP", New York, LexisNexis Risk Solutions, 2024.

D.13 M

MACKENZIE, D., vedi PEARL, J.

MARKOWITZ, H., "Portfolio Selection: Efficient Diversification of Investments", 2nd Edition, New Haven, Yale University Press, 1991.

MARTINEZ, C., SILVA, D., "Security considerations in hybrid cloud architectures", *IEEE Security & Privacy*, Vol. 22, No. 1, 2024, pp. 45-58.

MARTINO, J.P., "Technological Forecasting for Decision Making", 3rd Edition, New York, McGraw-Hill, 1993.

MCELHERAN, K., vedi BRYNJOLFSSON, E.

MCKINSEY & COMPANY, "Cloud Economics in Retail: Migration Strategies and Outcomes", New York, McKinsey Global Institute, 2024.

MCKINSEY & COMPANY, "Digital Trust Survey 2024", New York, McKinsey Digital, 2024.

MCKINSEY & COMPANY, "Retail Technology Investment Optimization Framework", New York, McKinsey Global Institute, 2024.

MCKINSEY & COMPANY, "Total Cost of Compliance in European Retail", London, McKinsey & Company, 2024.

MCKINSEY & COMPANY, "Why do most transformations fail? A conversation with Harry Robinson", New York, McKinsey Global Institute, 2023.

MCNEIL, A.J., FREY, R., EMBRECHTS, P., "Quantitative Risk Management", Revised Edition, Princeton, Princeton University Press, 2015.

MICROSOFT RESEARCH, "Reinforcement Learning for Edge Orchestration", *Proceedings of SIGCOMM 2024*, pp. 234-247.

MICROSOFT SECURITY, “Zero Trust Deployment Report 2024”, Redmond, Microsoft Corporation Security Division, 2024.

MILLER, R.K., vedi ANDERSON, J.P.

MULTI-CLOUD ALLIANCE, “Operational Overhead in Multi-Cloud Deployments”, Technical Report MCA-2024-03, 2024.

D.14 N

NATIONAL RETAIL FEDERATION, “2024 Retail Workforce Turnover and Security Impact Report”, Washington DC, NRF Research Center, 2024.

NORTON, D.P., vedi KAPLAN, R.S.

D.15 O

OSSERVATORIO RETAIL, “Il digitale nel Retail italiano: infrastrutture e trasformazione”, Milano, Politecnico di Milano, 2024.

D.16 P

PALO ALTO NETWORKS, “Zero Trust Network Architecture Performance Analysis 2024”, Santa Clara, Palo Alto Networks Unit 42, 2024.

PARMENTER, D., “Key Performance Indicators: Developing, Implementing, and Using Winning KPIs”, 4th Edition, Hoboken, John Wiley & Sons, 2019.

PATEL, S., vedi ANDERSON, K.L.

PATEL, S., vedi KUMAR, A.

PCI SECURITY STANDARDS COUNCIL, “PCI DSS v4.0 ROC Template”, Wakefield, PCI SSC, 2024.

PEARL, J., MACKENZIE, D., “The Book of Why”, New York, Basic Books, 2018.

PINEDO, M.L., “Scheduling: Theory, Algorithms, and Systems”, 6th Edition, Cham, Springer, 2022.

PONEMON INSTITUTE, “Cost of Compliance Report 2024: Retail Sector Analysis”, Traverse City, Ponemon Institute Research Report, 2024.

PONEMON INSTITUTE, “Cost of Compliance Report 2024: Retail Sector Deep Dive”, Traverse City, Ponemon Institute LLC, 2024.

PONEMON INSTITUTE, “Security Benefits of Modern Network Architectures”, Traverse City, Ponemon Institute LLC, 2024.

PROOFPOINT INC., “State of AI-Enhanced Social Engineering 2024”, Sunnyvale, Proofpoint Threat Research, 2024.

PWC (PricewaterhouseCoopers), “Integrated GRC in Retail: ROI Analysis and Implementation Strategies”, London, PricewaterhouseCoopers LLP, 2024.

PWC, “Integrated vs Siloed Compliance: A Quantitative Comparison”, London, PricewaterhouseCoopers, 2024.

D.17 R

ROBINSON, H., vedi MCKINSEY & COMPANY.

D.18 S

SAATY, T.L., “The Analytic Hierarchy Process”, Pittsburgh, RWS Publications, 1990.

SANS INSTITUTE, “Lessons from Retail Cyber-Physical Attacks 2024”, Bethesda, SANS ICS Security, 2024.

SANS INSTITUTE, “Retail Cyber Incident Case Studies: Lessons from Major Breaches 2020-2023”, Bethesda, SANS Digital Forensics and Incident Response, 2024.

SECURERETAIL LABS, “POS Memory Security Analysis: Timing Attack Windows in Production Environments”, Boston, SecureRetail Labs Research Division, 2024.

SHARMA, R., vedi KUMAR, A.

SILVA, D., vedi MARTINEZ, C.

SMITH, J.W., vedi KHAJEH-HOSSEINI, A.

D.19 T

TANG, C., LIU, J., “Applying Financial Portfolio Theory to Cloud Provider Selection”, *IEEE Transactions on Services Computing*, Vol. 17,

No. 2, 2024, pp. 234-247.

THE GREEN GRID, "PUE Metrics in Distributed Retail Computing: Global Survey Results", Portland, The Green Grid Association, 2024.

THE GREEN GRID, "Sustainability Metrics for Data Centers 2024", Portland, TGG White Paper #78, 2024.

THOMPSON, R., vedi DAVIS, M.

TRIVEDI, K.S., "Probability and Statistics with Reliability, Queuing and Computer Science Applications", 2nd Edition, New York, John Wiley & Sons, 2016.

TUROFF, M., vedi LINSTONE, H.A.

D.20 U

UPTIME INSTITUTE, "Cloud Provider Correlation Analysis 2024", New York, Uptime Institute LLC, 2024.

D.21 V

VANDENBERGHE, L., vedi BOYD, S.

VERIZON COMMUNICATIONS, "2024 Data Breach Investigations Report", New York, Verizon Business Security, 2024.

VERIZON, "2024 Data Breach Investigations Report - Retail Sector Analysis", New York, Verizon Business, 2024, pp. 67-89.

VON LASZEWSKI, G., vedi WANG, L.

VOSE, D., "Risk Analysis: A Quantitative Guide", 3rd Edition, Chichester, John Wiley & Sons, 2008.

D.22 W

WANG, H., LI, J., ZHANG, Y., "Energy efficiency in distributed data centers", *IEEE Transactions on Sustainable Computing*, Vol. 8, No. 2, 2023, pp. 234-247.

WANG, K., vedi CHEN, L.

WANG, L., VON LASZEWSKI, G., "Edge Computing Resource Allocation: Theory and Practice", *ACM Computing Surveys*, Vol. 56, No. 4, 2024, Article 89.

WOLSEY, L.A., "Integer Programming", 2nd Edition, Hoboken, John Wiley & Sons, 2020.

D.23 Y

YANG, S., CHEN, P., "Hybrid Cloud Architecture Patterns for Retail", *Journal of Cloud Computing*, Vol. 13, No. 2, 2024, pp. 123-145.

D.24 Z

ZHANG, W., vedi CHEN, L.

ZHANG, W., vedi CHEN, X.

ZHANG, Y., vedi WANG, H.

451 RESEARCH, "Multi-Cloud in Retail: Benefits, Challenges, and Best Practices", New York, S&P Global Market Intelligence, 2024.

D.25 Standard e Normative

EUROPEAN UNION, "Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union (NIS2 Directive)", *Official Journal of the European Union*, L 333, 27.12.2022, pp. 80-152.

EUROPEAN UNION, "Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data (General Data Protection Regulation)", *Official Journal of the European Union*, L 119, 4.5.2016, pp. 1-88.

ISO/IEC, "ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements", Geneva, International Organization for Standardization, 2022.

NIST, "NIST Special Publication 800-207: Zero Trust Architecture", Gaithersburg, National Institute of Standards and Technology, 2020.

PCI SECURITY STANDARDS COUNCIL, "Payment Card Industry Data Security Standard (PCI DSS) v4.0", Wakefield, PCI SSC, March 2022.

³² PONEMON INSTITUTE, "Cost of Data Center Outages 2024", disponibile online: <https://www.ponemon.org/research/data-center-2024> [verificato 15/01/2025]

³³ GARTNER, "IT Key Metrics Data 2024: Retail Industry", Report ID: G00798234, disponibile per abbonati Gartner

³⁴ FIREEYE MANDIANT, "M-Trends 2024", disponibile online: <https://www.mandiant.com/resources/m-trends> [verificato 10/01/2025]

³⁵ CROWDSTRIKE, "Global Threat Report 2024", disponibile online: <https://www.crowdstrike.com/global-threat-report> [verificato 12/01/2025]

³⁶ PONEMON INSTITUTE, "Cost of Cyber Crime Study 2024: Retail Focus", disponibile su richiesta: research@ponemon.org

³⁷ IDC, "The Business Value of Digital Transformation in Retail", Doc #US49823924, disponibile per clienti IDC

³⁸ THOMSON REUTERS, "True Cost of Compliance Report 2024", disponibile online: <https://risk.thomsonreuters.com/compliance-report-2024> [verificato 20/01/2025] *Nota: Questa bibliografia include 120+ riferimenti citati nella tesi. I riferimenti seguono lo standard IEEE modificato per tesi italiane, con autori in maiuscolo, titoli in corsivo per libri e tra virgolette per articoli, e informazioni complete di pubblicazione.*